

:ta_contactus)

https%3A%2F%2Fdocs.aws.amazon.com%2FIAM%2Flatest%2FUserGuide%2Fgetting-started-reduce-permissions.html)



(<https://docs.aws.amazon.com>).



Get started
(#)

Service guides
(#)

Developer tools
(#)



[Documentation](https://docs.aws.amazon.com/index.html)

(<https://docs.aws.amazon.com/index.html>)



[AWS Identity and Access Management](https://docs.aws.amazon.com/iam/index.html)

(<https://docs.aws.amazon.com/iam/index.html>)



Use...

Prepare for least-privilege permissions

[↓ PDF \(/pdfs/IAM/latest/UserGuide/iam-ug.pdf#getting-started-reduce-permissions\)](#)

[↓ RSS \(aws-iam-release-notes.rss\)](#)

[↓ Markdown \(getting-started-reduce-permissions.md\)](#)



Focus mode

Related resources

[AWS Identity and Access Management API Reference](#)

(<https://docs.aws.amazon.com/IAM/latest/APIReference/index.html>)

[AWS CLI commands for AWS Identity and Access Management](#)

(<https://docs.aws.amazon.com/cli/latest/reference/iam/>)

[SDKs & Tools](#) [↗](#) (<https://aws.amazon.com/tools/>)

▼ Recommended tasks

Learn about

[Understand how to review last accessed information for IAM](#)

(<https://docs.aws.amazon.com/IAM/latest/UserGuide/getting-started-reduce-permissions-last-accessed.html>)

[Security best practices for IAM management](#)

(<https://docs.aws.amazon.com/IAM/latest/UserGuide/best-practices.html>)

[Security concepts and best practices for CloudFormation](#)

(<https://docs.aws.amazon.com/prescriptive-guidance/latest/least-privilege-cloudformation/introduction.html>)

[Implement least-privilege access for AWS KMS key security](https://docs.aws.amazon.com/kms/latest/developerguide/least-privilege.html)
(<https://docs.aws.amazon.com/kms/latest/developerguide/least-privilege.html>)

How to

[Create a permission set for IAM Identity Center](https://docs.aws.amazon.com/singlesignon/latest/userguide/howtocreatepermissionset.html)
(<https://docs.aws.amazon.com/singlesignon/latest/userguide/howtocreatepermissionset.html>)

[Restrict use of the root user for security](https://docs.aws.amazon.com/prescriptive-guidance/latest/aws-startup-security-baseline/acct-02.html)
(<https://docs.aws.amazon.com/prescriptive-guidance/latest/aws-startup-security-baseline/acct-02.html>)

[Generate a policy based on user access activity](https://docs.aws.amazon.com/IAM/latest/UserGuide/getting-started_reduce-permissions-edit-policy.html)
(https://docs.aws.amazon.com/IAM/latest/UserGuide/getting-started_reduce-permissions-edit-policy.html)

[Find and navigate IAM resources quickly using console search](https://docs.aws.amazon.com/IAM/latest/UserGuide/console_search.html)
(https://docs.aws.amazon.com/IAM/latest/UserGuide/console_search.html)

[Install or update the latest version of the AWS CLI](https://docs.aws.amazon.com/cli/latest/userguide/getting-started-install.html)
(<https://docs.aws.amazon.com/cli/latest/userguide/getting-started-install.html>)

► Recently added to this guide

Did this page help you?

 Yes

 No

Provide feedback (https://docs.aws.amazon.com/feedback/doc-feedback.html?hidden_service_name=IAM&topic_url=https%3A%2F%2Fdocs.aws.amazon.com%2FIAM%2Flatest%2FUserGuide%2Fgetting-started-reduce-permissions.html)

Using *least-privilege permissions* is an IAM best practice recommendation. The concept of least-privilege permissions is to grant users the permissions required to perform a task and no more. As you get set up, consider how you are going to support least-privilege permissions. The root user, the administrative user, and the emergency access IAM user have powerful permissions that aren't required for everyday tasks. While you are learning about AWS and its different services we recommend that you create at least one additional user in IAM Identity Center with lesser permissions that you can use in different scenarios. You can use IAM policies to define the actions that can be taken on specific resources under specific conditions and then connect to those resources with your lesser privileged account.

If you are using IAM Identity Center, consider using IAM Identity Center permissions sets to get started. To learn more, see [Create a permission set](#)

(<https://docs.aws.amazon.com//singlesignon/latest/userguide/howtocreatepermissionset.html>) in *Identity Center User Guide*.

If you aren't using IAM Identity Center, use IAM roles to define the permissions for different entities. To learn more, see [IAM role creation \(/id_roles_create.html\)](#).

Both IAM roles and IAM Identity Center permissions sets can use AWS managed policies for job functions. For details on the permissions granted by these policies, see [AWS managed for job functions \(/access_policies_job-functions.html\)](#).

Important

Keep in mind that AWS managed policies might not grant least-privilege permissions for your specific use cases because they're available for use by all AWS customers. After getting set up, we recommend that you use IAM Access Analyzer to generate least-privilege policies based on your access activity that's logged in AWS CloudTrail. For information about policy generation, see [IAM Access Analyzer policy generation \(/https://docs.aws.amazon.com/IAM/latest/UserGuide/access-analyzer-policy-generation.html\)](#).

When you are getting started, we recommend that you use AWS managed policies to grant permissions. After a predefined sample period of activity (such as 90 days) has passed, you review the services that people and workloads have accessed. Then you can create a new customer managed policy with reduced permissions to replace the AWS managed policy. The new policy should include only the services that were accessed during the sample period. Update your permissions to remove the AWS managed policy and attach the new customer managed policy created.

View related pages Abstracts generated by AI

[<](#) [1](#) [2](#) [>](#)

Waf › developerguide
[Identity-based policy examples for AWS WAF...](#)
IAM policies grant least-privilege permissions managing AWS WAF Classic console access, MFA, policy validation, resource migration.

May 7, 2026

Verifiedpermissions › userguide
[Identity-based policy examples for Amazon...](#)
IAM policies grant least-privilege permissions managing Verified Permissions console access, MFA, Access Analyzer validation.

May 7, 2026

Vpn › clientvpn-admin
[Identity-based policy examples for AWS](#)
IAM policies grant least-privilege permissions validate via Access Analyzer enforce MFA securing VPN resources.

May 7, 2026

Discover highly rated pages Abstracts generated by AI

[<](#) [1](#) [2](#) [>](#)

IAM › UserGuide What is IAM? (https://docs.aws.amazon....) IAM controls AWS resource access, managing authentication, authorization, and permissions across accounts. May 8, 2026	IAM › UserGuide Security best practices in IAM... Apply least-privilege permissions, use MFA, temporary credentials, and IAM Access Analyzer secure AWS resources. May 8, 2026	IAM › UserGuide IAM Identities (https://docs.aws.am...) IAM identities—users, groups, roles—link permissions to actions, resources, and conditions. May 8, 2026
--	---	--

Get Started

AWS Hands-On Tutorials [↗](#)

(https://aws.amazon.com/getting-started/hands-on/)

AWS Solutions Library [↗](#)

(https://aws.amazon.com/solutions-library/)

AWS Decision Guides [↗](#)

(https://aws.amazon.com/getting-started/decision-guides/)

Service Guides

Choosing a generative AI service

(https://docs.aws.amazon.com/generative-ai-on-aws-how-to-choose/)

AWS Service guides

(https://docs.aws.amazon.com/#/products)

AWS CLI Tutorials on GitHub [↗](#)

(https://github.com/aws-samples/sample-developer-tutorials)

Developer Tools

AWS Code Example Library

(https://docs.aws.amazon.com/code-library/latest/ug/what-is-code-library.html)

AWS CLI

(https://docs.aws.amazon.com/cli/)

AWS Builder Center [↗](#)

(https://builder.aws.com/)

AWS Developer Tools Blog [↗](#)

(https://aws.amazon.com/blogs/developer/)

Helpful Links

Download the AWS Docs MCP Server [↗](#)

(https://github.com/aws-labs/mcp/tree/main/docs/automation-mcp-server)

Sign into the AWS Console [↗](#)

(https://console.aws.amazon.com/)

AWS re:Post [↗](#)

(https://repost.aws/)

Top

Privacy (https://aws.amazon.com/privacy) | Site terms (https://aws.amazon.com/terms) | Cookie preferences (#) | © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

English



=docs_headercta_contactus)

3&topic_url=https%3A%2F%2Fdocs.aws.amazon.com%2FAmazonS3%2Flatest%2Fuserguide%2FUsingEncryption.html)



(<https://docs.aws.amazon.com>).



Get started
(#)

Service guides
(#)

Developer tools
(#)



[Documentation](https://docs.aws.amazon.com/index.html)

(<https://docs.aws.amazon.com/index.html>)



[Amazon Simple Storage Service \(S3\)](https://docs.aws.amazon.com/s3/index.html)

(<https://docs.aws.amazon.com/s3/index.html>)



User ...

Protecting data with encryption

[↓ PDF \(/pdfs/AmazonS3/latest/userguide/s3-userguide.pdf#UsingEncryption\)](#)

[↓ RSS \(s3-userguide-rss-updates.rss\)](#)

[↓ Markdown \(UsingEncryption.md\)](#)



Focus mode

Related resources

[Amazon S3 API Reference](https://docs.aws.amazon.com/AmazonS3/latest/API/Welcome.html) (<https://docs.aws.amazon.com/AmazonS3/latest/API/Welcome.html>)

[AWS CLI commands for Amazon S3](https://docs.aws.amazon.com/cli/latest/reference/s3/) (<https://docs.aws.amazon.com/cli/latest/reference/s3/>)

[SDKs & Tools](https://aws.amazon.com/tools/) [↗](#) (<https://aws.amazon.com/tools/>)

▼ Recommended tasks

Learn about

[Understand the Amazon S3 Encryption Client](#)

(<https://docs.aws.amazon.com/amazon-s3-encryption-client/latest/developerguide/what-is-s3-encryption-cli>)

[Understand default encryption for new S3 object uploads](#)

(<https://docs.aws.amazon.com/AmazonS3/latest/userguide/default-encryption-faq.html>)

[Understand how to encrypt DynamoDB data at rest](#)

(<https://docs.aws.amazon.com/amazondynamodb/latest/developerguide/EncryptionAtRest.html>)

[Understand supported encryption algorithms for Amazon S3](#)

(<https://docs.aws.amazon.com/amazon-s3-encryption-client/latest/developerguide/encryption-algorithms.htm>)

[Understand server-side encryption for Amazon S3](#)

(<https://docs.aws.amazon.com/AmazonS3/latest/userguide/serv-side-encryption.html>)

How to

[Configure S3 bucket encryption using AWS KMS keys](https://docs.aws.amazon.com/AmazonS3/latest/userguide/specifying-kms-encryption.html)

(<https://docs.aws.amazon.com/AmazonS3/latest/userguide/specifying-kms-encryption.html>)

[Configure server-side encryption for S3 objects and buckets](https://docs.aws.amazon.com/AmazonS3/latest/userguide/specifying-s3-encryption.html)

(<https://docs.aws.amazon.com/AmazonS3/latest/userguide/specifying-s3-encryption.html>)

Did this page help you?

 Yes

 No

Provide feedback ([https://docs.aws.amazon.com/feedback/doc-feedback.html?](https://docs.aws.amazon.com/feedback/doc-feedback.html?hidden_service_name=S3&topic_url=https%3A%2F%2Fdocs.aws.amazon.com%2FAmazonS3%2Flatest%2Fuserguide/specifying-s3-encryption.html)

[hidden_service_name=S3&topic_url=https%3A%2F%2Fdocs.aws.amazon.com%2FAmazonS3%2Flatest%2Fuserguide/specifying-s3-encryption.html](https://docs.aws.amazon.com/feedback/doc-feedback.html?hidden_service_name=S3&topic_url=https%3A%2F%2Fdocs.aws.amazon.com%2FAmazonS3%2Flatest%2Fuserguide/specifying-s3-encryption.html))

Important

Amazon S3 now applies server-side encryption with Amazon S3 managed keys (SSE-S3) at the object level of encryption for every bucket in Amazon S3. Starting January 5, 2023, all new Amazon S3 buckets are automatically encrypted at no additional cost and with no impact on existing buckets. You can view the automatic encryption status for S3 bucket default encryption configuration and for individual objects in CloudTrail logs, S3 Inventory, S3 Storage Lens, the Amazon S3 console, and the AWS CLI. An additional Amazon S3 API response header in the AWS CLI and AWS SDKs. For more information, see [Default encryption FAQ \(https://docs.aws.amazon.com/AmazonS3/latest/userguide/default-encryption-faq.html\)](https://docs.aws.amazon.com/AmazonS3/latest/userguide/default-encryption-faq.html).

Data protection refers to protecting data while it's in transit (as it travels to and from Amazon S3) and at rest (while it is stored on disks in Amazon S3 data centers). You can protect data in transit by using Transport Layer Security (SSL/TLS) including hybrid post-quantum key exchange or TLS 1.3. For protecting data at rest in Amazon S3, you have the following options:

- **Server-side encryption** – Amazon S3 encrypts your objects before saving them on disks and then decrypts the objects when you download them.

All Amazon S3 buckets have encryption configured by default, and all new objects that you upload to a bucket are automatically encrypted at rest. Server-side encryption with Amazon S3 managed keys is the default encryption configuration for every bucket in Amazon S3. To use a different type of encryption, you can either specify the type of server-side encryption to use in your S3 PUT request or you can specify the default encryption configuration in the destination bucket.

If you want to specify a different encryption type in your PUT requests, you can use S3 with AWS Key Management Service (AWS KMS) keys (SSE-KMS), dual-layer server-side encryption with AWS KMS keys (DSSE-KMS), or server-side encryption with customer-provided keys (SSE-C). If you want a different default encryption configuration in the destination bucket, you can use SSE-KMS. For more information about changing the default encryption configuration for your bucket, see [Configuring default encryption \(./default-bucket-encryption.html\)](#).

When you change the default encryption configuration of your bucket to SSE-KMS, the encryption of existing Amazon S3 objects in the bucket is not changed. To change the encryption type of existing objects after updating the default encryption configuration to SSE-KMS, you can use S3 Batch Operations. You provide S3 Batch Operations with a list of objects, and Batch Operations performs the specified operation on billions of objects. For more information, see [Performing batch operations in bulk with Batch Operations \(./batch-ops.html\)](#) and the *AWS Storage Blog* article [retroactively encrypt existing objects in Amazon S3 using S3 Inventory, Amazon Athena, and S3 Batch Operations](https://aws.amazon.com/blogs/security/how-to-retroactively-encrypt-existing-objects-in-amazon-s3-using-s3-inventory-amazon-athena-and-s3-batch-operations/) (https://aws.amazon.com/blogs/security/how-to-retroactively-encrypt-existing-objects-in-amazon-s3-using-s3-inventory-amazon-athena-and-s3-batch-operations/).

For more information about each option for server-side encryption, see [Protecting data with server-side encryption \(./serv-side-encryption.html\)](#).

To configure server-side encryption, see:

- [Specifying server-side encryption with Amazon S3 managed keys \(SSE-S3\) \(./specifying-s3-managed-keys.html\)](#)
- [Specifying server-side encryption with AWS KMS \(SSE-KMS\) \(./specifying-kms-encryption.html\)](#)
- [Specifying dual-layer server-side encryption with AWS KMS keys \(DSSE-KMS\) \(./specifying-ds-kms-encryption.html\)](#)
- [Specifying server-side encryption with customer-provided keys \(SSE-C\) \(./specifying-customer-provided-keys.html\)](#)
- **Client-side encryption** – You encrypt your data client-side and upload the encrypted data to Amazon S3. In this case, you manage the encryption process, encryption keys, and related tools.

To configure client-side encryption, see [Protecting data by using client-side encryption \(./UsingClientSideEncryption.html\)](#).

To see which percentage of your storage bytes are encrypted, you can use Amazon S3 Storage Lens. Storage Lens is a cloud-storage analytics feature that you can use to gain organization-wide insights into storage usage and activity. For more information, see [Assessing your storage activity and usage with Storage Lens \(https://docs.aws.amazon.com/AmazonS3/latest/userguide/storage_lens.html\)](#). For a complete list of metrics, see [S3 Storage Lens metrics glossary \(https://docs.aws.amazon.com/AmazonS3/latest/userguide/storage_lens_metrics_glossary.html\)](#).

For more information about server-side encryption, client-side encryption, and encryption key management, see the following topics.

Topics

- [Protecting data with server-side encryption \(./serv-side-encryption.html\)](#)
- [Protecting data by using client-side encryption \(./UsingClientSideEncryption.html\)](#)
- [Protecting data in transit with encryption \(./UsingEncryptionInTransit.html\)](#)

View related pages Abstracts generated by AI

AmazonS3 › userguide

[Using server-side encryption with Amazon S3 managed...](#)

SSE-S3 encrypts S3 objects at rest by default; use x-amz-server-side-encryption header configure uploads.

May 8, 2026

Code-library › ug

[Amazon S3 examples using SDK for Ruby...](#)

Ruby SDK examples cover S3 bucket creation, presigned URL uploads, Lambda triggers, encryption, policies, CORS.

May 7, 2026

Codebuild :

[Update :](#)

(<https://c>

Modify Co

export tes

customer

ZIP, add t

May 8, 20

Discover highly rated pages Abstracts generated by AI

AmazonS3 › userguide

[What is Amazon S3?](#)

(<https://docs.aws.amazon.com/...>

Scalable object storage optimizes costs via storage classes, lifecycle policies, versioning, access controls, strong PUT/DELETE consistency.

May 8, 2026

AmazonS3 › userguide

[General purpose bucket naming rules...](#)

S3 bucket naming rules cover length, characters, uniqueness, GUID usage, avoiding periods, account regional namespace conventions.

May 8, 2026

AmazonS3

[Hosting](#)

[Amazon](#)

Amazon S

SSE-KMS

CloudFro

access cor

May 8, 20

Get Started

AWS Hands-On Tutorials 
(<https://aws.amazon.com/getting-started/hands-on/>)

AWS Solutions Library 
(<https://aws.amazon.com/solutions-library/>)

AWS Decision Guides 
(<https://aws.amazon.com/decision-guides/>)

Service Guides

Choosing a generative AI service 
(<https://docs.aws.amazon.com/generative-ai-on-aws-how-to-choose/>)

AWS Service guides 
(<https://docs.aws.amazon.com/service-guides/>)

AWS CLI Tutorials 
(<https://github.com/aws-samples>)

Developer Tools

AWS Code Example Library 
(<https://docs.aws.amazon.com/code-library/latest/ug/what-is-code-library.html>)

AWS CLI 
(<https://docs.aws.amazon.com/cli/>)

AWS Builder Center 
(<https://builder.aws.com/>)

Helpful Links

Download the AWS Docs MCP Server 
(<https://github.com/awslabs/mcp/tree/main/docs-generation-mcp-server>)

Sign into the AWS Console 
(<https://console.aws.amazon.com/>)

AWS re:Post 
(<https://repost.aws/>)

Top

started/decision-
guides/)

samples/sample-
developer-tutorials)

AWS Developer
Tools Blog [↗](https://aws.amazon.com/blogs/developer/)
(<https://aws.amazon.com/blogs/developer/>)

Privacy (<https://aws.amazon.com/privacy>) | Site terms (<https://aws.amazon.com/terms>) | Cookie
preferences (#) | © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

English



id=docs_headercta_contactus)

=IAM&topic_url=https%3A%2F%2Fdocs.aws.amazon.com%2FIAM%2Flatest%2FUserGuide%2Fid_credentials_mfa.html)



(<https://docs.aws.amazon.com>).



Get started
(#)

Service guides
(#)

Developer tools
(#)



[Documentation](https://docs.aws.amazon.com/index.html)

(<https://docs.aws.amazon.com/index.html>)



[AWS Identity and Access Management](https://docs.aws.amazon.com/iam/index.html)

(<https://docs.aws.amazon.com/iam/index.html>)



Use...

AWS Multi-factor authentication in IAM

[↓ PDF \(/pdfs/IAM/latest/UserGuide/iam-ug.pdf#id_credentials_mfa\)](#)

[↓ RSS \(aws-iam-release-notes.rss\)](#)

[↓ Markdown \(id_credentials_mfa.md\)](#)

☐ Focus mode

On this page

[MFA types\(#id_credentials_mfa-types\)](#)

[MFA recommendations\(#id_credentials_mfa-recommendations\)](#)

[Additional resources\(#id_credentials_mfa-resources\)](#)

Related resources

[AWS Identity and Access Management API Reference](https://docs.aws.amazon.com/IAM/latest/APIReferen) (<https://docs.aws.amazon.com/IAM/latest/APIReferen>

[AWS CLI commands for AWS Identity and Access Management](https://docs.aws.amazon.com/cli/latest/rel) (<https://docs.aws.amazon.com/cli/latest/rel>

[SDKs & Tools](https://aws.amazon.com/tools/) [↗](#) (<https://aws.amazon.com/tools/>)

▼ Recommended tasks

How to

[Troubleshoot sign-in issues for AWS account access](#)

(<https://docs.aws.amazon.com/signin/latest/userguide/troubleshooting-sign-in-issues.html>)

[Recover and manage MFA access for AWS account and IAM users](#)

(https://docs.aws.amazon.com/IAM/latest/UserGuide/id_credentials_mfa_lost-or-broken.html)

[Configure a virtual MFA device for an IAM user](#)

(https://docs.aws.amazon.com/IAM/latest/UserGuide/id_credentials_mfa_enable_virtual.html)

Configure MFA prompt settings for user sign-in

(<https://docs.aws.amazon.com/singlesignon/latest/userguide/mfa-getting-started.html>)

Install or update the latest version of the AWS CLI

(<https://docs.aws.amazon.com/cli/latest/userguide/getting-started-install.html>)

Learn about

Understand multi-factor authentication for AWS root user

(<https://docs.aws.amazon.com/IAM/latest/UserGuide/enable-mfa-for-root.html>)

Understand different AWS user types and how to sign in

(<https://docs.aws.amazon.com/signin/latest/userguide/user-types-list.html>)

► Recently added to this guide

Did this page help you?

 Yes

 No

Provide feedback (<https://docs.aws.amazon.com/feedback/doc-feedback.html?>

[hidden_service_name=IAM&topic_url=https%3A%2F%2Fdocs.aws.amazon.com%2FIAM%2Flatest%2FUserGuide](https://docs.aws.amazon.com/feedback/doc-feedback.html?hidden_service_name=IAM&topic_url=https%3A%2F%2Fdocs.aws.amazon.com%2FIAM%2Flatest%2FUserGuide)

For increased security, we recommend that you configure multi-factor authentication (MFA) for the AWS account root user and for all IAM users who access AWS resources. You can enable MFA for the AWS account root user of all AWS accounts, in managed accounts, management accounts, and member accounts, as well as for your IAM users. We recommend using phishing-resistant MFA such as passkeys and security keys whenever possible. These authenticators use public key cryptography and are resistant to phishing, man-in-the-middle attacks, providing a stronger level of security than TOTP-based options.

MFA is enforced for all account types for their root user. For more information, see [Secure Organizations account root user credentials](#) ([./root-user-best-practices.html#ru-bp-organizational-root-user-credentials](#)).

When you enable MFA for the root user, it affects only the root user credentials. IAM users have distinct identities with their own credentials, and each identity has its own MFA configuration. For information about using MFA to protect the root user, see [Multi-factor authentication for the root user](#) ([./enable-mfa-for-root.html](#)).

Your AWS account root user and IAM users can register up to eight MFA devices of any type. MFA devices can provide flexibility and help you reduce the risk of access interruption if a

broken. You only need one MFA device to sign in to the AWS Management Console or create the AWS CLI.

Note

We recommend that you require your human users to use temporary credentials with MFA. Have you considered using AWS IAM Identity Center? You can use IAM Identity Center to manage access to multiple AWS accounts and provide users with MFA-protected, single sign-on to all their assigned accounts from one place. With IAM Identity Center, you can create user identities in IAM Identity Center or easily connect to your existing SAML 2.0 compatible provider. For more information, see [What is IAM Identity Center?](https://docs.aws.amazon.com/singlesignon/latest/userguide/what-is.html)

(<https://docs.aws.amazon.com/singlesignon/latest/userguide/what-is.html>) in the *AWS IAM User Guide*.

MFA adds extra security that requires users to provide unique authentication from an AWS MFA mechanism in addition to their sign-in credentials when they access AWS websites or services.

MFA types

AWS supports the following MFA types:

Contents

- [Passkeys and security keys \(/id_credentials_mfa.html#passkeys-security-keys-for-iam-users\)](#)
- [Virtual authenticator applications \(/id_credentials_mfa.html#virtual-auth-apps-for-iam-users\)](#)
- [Hardware TOTP tokens \(/id_credentials_mfa.html#hardware-totp-token-for-iam-users\)](#)

Passkeys and security keys

AWS Identity and Access Management supports passkeys and security keys for MFA. Based on FIDO2, passkeys use public key cryptography to provide strong, phishing-resistant authentication that is more secure than passwords. AWS supports two types of passkeys: device-bound passkeys (security keys) and synced passkeys.

- **Security keys:** These are physical devices, like a YubiKey, used as a second factor for authentication. A security key can support multiple root user accounts and IAM users.
- **Synced passkeys:** These use credential managers from providers such as Google, Apple, and third-party services like 1Password, Dashlane, and Bitwarden as a second factor.

You can use built-in biometric authenticators, like Touch ID on Apple MacBooks, to unlock your device and sign in to AWS. Passkeys are created with your chosen provider using your device PIN. You can also use a cross-device authentication (CDA) passkey from one device,

hardware security key, to sign in on another device like a laptop. For more information, see [authentication](https://passkeys.dev/docs/reference/terms/#cross-device-authentication-cda) [↗] (<https://passkeys.dev/docs/reference/terms/#cross-device-authentication-cda>)

You can sync passkeys across your devices to facilitate sign-ins with AWS, enhancing usability. For more information about enabling passkeys and security keys, see [Enable a passkey or root user \(console\)](#) ([./enable-fido-mfa-for-root.html](/enable-fido-mfa-for-root.html)) .

The FIDO Alliance maintains a list of all [FIDO Certified products](https://fidoalliance.org/certified-products/) [↗] (<https://fidoalliance.org/certified-products/>) that are compatible with FIDO specifications.

Virtual authenticator applications

A virtual authenticator application runs on a phone or other device and emulates a physical authenticator. Apps implement the [time-based one-time password \(TOTP\) algorithm](https://datatracker.ietf.org/doc/html/rfc6238) [↗] (<https://datatracker.ietf.org/doc/html/rfc6238>) and support multiple tokens on a single device. Each token generates a valid code from the device when prompted during sign-in. Each token assigned to a user can't type a code from another user's token to authenticate.

We recommend that you use phishing-resistant MFA such as [passkeys or security keys](#) ([#passkeys-iam-users](#)) for the strongest protection. If you are not yet able to use passkeys or security keys, we recommend that you use a virtual MFA device as an interim measure while waiting for hardware purchase. You wait for your hardware to arrive. For a list of a few supported apps that you can use, see [Multi-Factor Authentication \(MFA\)](#) [↗] (<https://aws.amazon.com/iam/features/mfa/?audit=2>)

For instructions on setting up a virtual MFA device for an IAM user, see [Assign a virtual MFA device \(IAM console\)](#) ([./id_credentials_mfa_enable_virtual.html](/id_credentials_mfa_enable_virtual.html)) .

Note

Unassigned virtual MFA devices in your AWS account are deleted when you're adding new devices either via the AWS Management Console or during the sign-in process. Unassigned devices are devices in your account but not used by account root user or IAM users during the sign-in process. They're deleted so new virtual MFA devices can be added to your account. You can reuse device names.

- To view unassigned virtual MFA devices in your account, you can use either the [awscli](#) [↗] (<https://awscli.amazonaws.com/v2/documentation/api/latest/reference/iam/devices.html>) AWS CLI command or [API](#) [↗] (https://docs.aws.amazon.com/IAM/latest/APIReference/API_ListVirtualMFADevices.html)
- To deactivate a virtual MFA device, you can use either the [deactivate-mfa-device](#) [↗] (<https://awscli.amazonaws.com/v2/documentation/api/latest/reference/iam/deactivate-mfa-device.html>) AWS CLI command or [API](#) [↗] (https://docs.aws.amazon.com/IAM/latest/APIReference/API_DeactivateMFADevice.html) . The device will become unassigned.

- To attach an unassigned virtual MFA device to your AWS account root user or IAM user, you need the authentication code generated by the device along with either the [enable-mfa-device](https://awscli.amazonaws.com/v2/documentation/api/latest/reference/iam/enable-mfa-device) CLI command or [API](https://docs.aws.amazon.com/IAM/latest/APIReference/API_EnableMFADevice) call.

Hardware TOTP tokens

A hardware device generates a six-digit numeric code based on the [time-based one-time password algorithm](https://datatracker.ietf.org/doc/html/rfc6238) (https://datatracker.ietf.org/doc/html/rfc6238). The user must type a valid code from the second webpage during sign-in.

These tokens are used exclusively with AWS accounts. You can only use tokens that have token seeds shared securely with AWS. Token seeds are secret keys generated at the time of token purchase. Tokens purchased from other sources will not function with IAM. To ensure compatibility, you must purchase a hardware MFA device from one of the following links: [OTP token](https://www.amazon.com/Amazon-Services/dp/B002CRN5X8) (https://www.amazon.com/Amazon-Services/dp/B002CRN5X8) or [OTP display card](https://www.amazon.com/Amazon-Services/dp/B00J4NGUO4) (https://www.amazon.com/Amazon-Services/dp/B00J4NGUO4).

- Each MFA device assigned to a user must be unique. A user cannot type a code from a device that is not assigned to them to be authenticated. For information on supported hardware MFA devices, see [Multi-Factor Authentication \(MFA\)](https://aws.amazon.com/iam/features/mfa/?audit=2019q1) (https://aws.amazon.com/iam/features/mfa/?audit=2019q1).
- If you want to use a physical MFA device, we recommend that you use security keys as hardware TOTP devices. Security keys have no battery requirements, are phishing resistant, and can be shared by multiple users on a single device.

You can enable a passkey or security key from the AWS Management Console only, not from the AWS API. Before you can enable a security key, you must have physical access to the device.

For instructions on setting up a hardware TOTP token for an IAM user, see [Assign a hardware TOTP token to an IAM user](https://docs.aws.amazon.com/IAM/latest/UserGuide/id_credentials_mfa_enable_physical.html) (./id_credentials_mfa_enable_physical.html).

Note

SMS text message-based MFA – AWS ended support for enabling SMS multi-factor authentication (MFA). We recommend that customers who have IAM users that use SMS text message-based MFA switch to one of the following alternative methods: [Passkey or security key](https://docs.aws.amazon.com/IAM/latest/UserGuide/id_credentials_mfa_enable_fido.html) (./id_credentials_mfa_enable_fido.html), [virtual \(software-based\) MFA device](https://docs.aws.amazon.com/IAM/latest/UserGuide/id_credentials_mfa_enable_virtual.html) (./id_credentials_mfa_enable_virtual.html), or [hardware MFA device](https://docs.aws.amazon.com/IAM/latest/UserGuide/id_credentials_mfa_enable_physical.html) (./id_credentials_mfa_enable_physical.html). You can identify the users in your account that use SMS MFA devices. In the IAM console, choose **Users** from the navigation pane, and look for **SMS** in the **MFA** column of the table.

MFA recommendations

To help secure your AWS identities, follow these recommendations for MFA authentication.

- We recommend that you use phishing-resistant MFA, such as [passkeys and security keys-for-iam-users](#) , as your MFA device. These FIDO-based authenticators provide the against attacks such as phishing.
- We recommend that you enable multiple MFA devices to the AWS account root user a AWS accounts. This allows you to raise the security bar in your AWS accounts and sim to highly privileged users, such as the AWS account root user.
- You can register up to **eight** MFA devices of any combination of the [currently support](#) (<https://aws.amazon.com/iam/features/mfa/>) with your AWS account root user and IAM u MFA devices, you only need one MFA device to sign in to the AWS Management Cons through the AWS CLI as that user. An IAM user must authenticate with an existing MF disable an additional MFA device.
- In the event of a lost, stolen, or inaccessible MFA device you can use one of the remain access the AWS account without performing the AWS account recovery procedure. If a stolen, it should be disassociated from the IAM principal with which it is associated.
- The use of multiple MFAs allows your employees in geographically dispersed location to use hardware-based MFA to access AWS without having to coordinate the physical hardware device between employees.
- The use of additional MFA devices for IAM principals allows you to use one or more M usage, while also maintaining physical MFA devices in a secure physical location such backup and redundancy.

Notes

- You cannot pass the MFA information for a security key or passkey to AWS STS request temporary credentials. You can obtain credentials for use with the AW! when using a security key or passkey by running the `aws login` command.
- You cannot use AWS CLI commands or AWS API operations to enable [FIDO seci](#) ([./id_credentials_mfa_enable_fido.html](#)) .
- You cannot use the same name for more than one root user or IAM MFA device

Additional resources

The following resources can help you learn more about MFA.

- For more information about using MFA to access AWS, see [MFA enabled sign-in](#) ([./cons](#)

- You can leverage IAM Identity Center to enable secure MFA access to your AWS access Center integrated apps, and the AWS CLI. For more information, see [Enable MFA in IAM](https://docs.aws.amazon.com/singlesignon/latest/userguide/mfa-getting-started.html) (<https://docs.aws.amazon.com/singlesignon/latest/userguide/mfa-getting-started.html>) .

View related pages ✦ Abstracts generated by AI

IAM › UserGuide

[Multi-factor authentication for AWS account root user...](#)

Secure AWS root user enabling MFA via passkeys, FIDO keys, virtual apps, hardware TOTP tokens.

May 8, 2026

IAM › UserGuide

[Assign a passkey or security key in the AWS Managemen...](#)

Assign passkeys, FIDO security keys, synced credentials, WebAuthn MFA configurations, IAM users, AWS Management Console registration.

May 8, 2026

Signin › user

[Manage A multi-fact](#)

Register, m keys, passk securing A

May 7, 202

Discover highly rated pages ✦ Abstracts generated by AI

IAM › UserGuide

[What is IAM?](#)

[\(https://docs.aws.amazon.com...](https://docs.aws.amazon.com...)

IAM controls AWS resource access, managing authentication, authorization, and permissions across accounts.

May 8, 2026

IAM › UserGuide

[Security best practices in IAM](#)

[\(https://docs.aws.amazon.com...](https://docs.aws.amazon.com...)

Apply least-privilege permissions, use MFA, temporary credentials, and IAM Access Analyzer secure AWS resources.

May 8, 2026

IAM › UserGu

[IAM Ident](#)

[\(https://do](https://do)

IAM identit roles—link authorized resources, c

May 8, 202

Get Started

AWS Hands-On Tutorials ↗

(<https://aws.amazon.com/getting-started/hands-on/>)

AWS Solutions Library ↗

(<https://aws.amazon.com/solutions/>)

AWS Decision Guides ↗

(<https://aws.amazon.com/getting-started/decision-guides/>)

Service Guides

Choosing a generative AI service

(<https://docs.aws.amazon.com/generative-ai-on-aws-how-to-choose/>)

AWS Service guides

(<https://docs.aws.amazon.com/#products>)

AWS CLI Tutorials

[get on GitHub ↗](https://github.com/awslabs/aws-samples/sample-developer-tutorials)
(<https://github.com/awslabs/aws-samples/sample-developer-tutorials>)

Developer Tools

AWS Code Example Library

(<https://aws.amazon.com/code-library/latest/ug/what-is-code-library.html>)

AWS CLI

(<https://docs.aws.amazon.com/cli/>)

AWS Builder Center ↗

(<https://builder.aws.com/>)

AWS Developer Tools Blog ↗

Helpful Links

Download the AWS Docs MCP Server ↗

(<https://github.com/awslabs/mcp/tree/main/docs/ai-assistant-mcp-server>)

Sign into the AWS Console ↗

(<https://console.aws.amazon.com/>)

AWS re:Post ↗

(<https://repost.aws/>)

Top

[Privacy \(https://aws.amazon.com/privacy\)](https://aws.amazon.com/privacy) | [Site terms \(https://aws.amazon.com/terms\)](https://aws.amazon.com/terms) | [Cookie preferences \(#\)](#) | © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

English ▼

.com/contact-us/?cmpid=docs_headercta_contactus)

'hidden_service_name=ElastiCache&topic_url=https%3A%2F%2Fdocs.aws.amazon.com%2FAmazonElastiCache%2Flatest%2Fdg%2FClusters.RBAC.html')



(<https://docs.aws.amazon.com>)



Get started
(#)

Service guides
(#)

Developer tools
(#)

AI resources
(#)



Documentation

(<https://docs.aws.amazon.com/index.html>)



Amazon ElastiCache

(<https://docs.aws.amazon.com/elasticache/index.html>)



User Guide

Role-Based Access Control (RBAC)

[PDF \(/pdfs/AmazonElastiCache/latest/dg/redis-ug.pdf#Clusters.RBAC\)](#)

[RSS \(amazon-elcr-release-notes.rss\)](#)

[Markdown \(Clusters.RBAC.md\)](#)

☐ Focus mode

On this page

[Specifying Permissions Using an Access String\(#Access-string\)](#)

[Applying RBAC to an ElastiCache Valkey or Redis OSS cache\(#rbac-using\)](#)

[Migrating from AUTH to RBAC\(#Migrate-From-RBAC-to-Auth\)](#)

[Migrating from RBAC to AUTH\(#Migrate-From-RBAC-to-AUTH-1\)](#)

▼ Recommended tasks

Learn about

[Understand authentication and authorization for ElastiCache](#)

(<https://docs.aws.amazon.com/AmazonElastiCache/latest/dg/auth-redis.html>)

[Understand the serverless, elastic file storage service](#)

(<https://docs.aws.amazon.com/efs/latest/ug/whatisefs.html>)

[Understand Amazon ElastiCache service authorization](#)

(https://docs.aws.amazon.com/service-authorization/latest/reference/list_amazonelasticache.html)

[Understand AWS Signature Version 4 for API requests](#)

(https://docs.aws.amazon.com/IAM/latest/UserGuide/reference_sigv.html)

[Authenticate connections to ElastiCache using IAM identities](#)

(<https://docs.aws.amazon.com/AmazonElastiCache/latest/dg/auth-iam.html>)

How to

[Disable access control on ElastiCache cache](#)

(<https://docs.aws.amazon.com/AmazonElastiCache/latest/dg/in-transit-encryption-disable.html>)

[Create a signed AWS API request for authentication](#)

(https://docs.aws.amazon.com/IAM/latest/UserGuide/reference_sigv-create-signed-request.html)

[Upgrade stunnel for secure EFS file system mounting with TLS](#)

(<https://docs.aws.amazon.com/efs/latest/ug/upgrading-stunnel.html>)

[Manage billing and tax settings for AWS accounts in India](#)

(<https://docs.aws.amazon.com/awsaccountbilling/latest/aboutv2/manage-account-payment-aispl.html>)

[Install or update the latest version of the AWS CLI](#)

<https://docs.aws.amazon.com/cli/latest/userguide/getting-started-install.html>

► Recently added to this guide

Did this page help you?☒ Yes☐ No[Provide feedback \(https://docs.aws.amazon.com/feedback/doc-feedback.html?](https://docs.aws.amazon.com/feedback/doc-feedback.html?hidden_service_name=ElastiCache&topic_url=https%3A%2F%2Fdocs.aws.amazon.com%2FAmazonElastiCache%2Flatest%2Fdg%2FClusters.RBAC.html)[hidden_service_name=ElastiCache&topic_url=https%3A%2F%2Fdocs.aws.amazon.com%2FAmazonElastiCache%2Flatest%2Fdg%2FClusters.RBAC.html\)](https://docs.aws.amazon.com/feedback/doc-feedback.html?hidden_service_name=ElastiCache&topic_url=https%3A%2F%2Fdocs.aws.amazon.com%2FAmazonElastiCache%2Flatest%2Fdg%2FClusters.RBAC.html)

With the Valkey and Redis OSS AUTH command as described in [Authenticating with the Valkey and Redis OSS AUTH command \(.auth.html\)](#) you can use Role-Based Access Control (RBAC). RBAC is also the only way to control access to serverless caches. This is available for Valkey 7.2 and onward, and Redis OSS 6.0 to 7.2.

RBAC enables you to:

- Control cache access through user groups. These user groups are designed as a way to organize access to cache
- With *authN*, have per user passwords as opposed to per cluster auth tokens.
- With *authZ*, have fine-grained user permissions.
- Base your cluster access on ACLs.

Unlike Valkey and Redis OSS AUTH, where all authenticated clients have full cache access if their token is authentic, RBAC enables you to assign users to sets depending on the users' desired roles. These sets are designed as a way to organize access to caches.

With RBAC, you create users and assign them specific permissions by using an access string, as described following. You assign the users to sets aligned with a specific role (administrators, human resources) that are then deployed to one or more ElastiCache caches. By doing this, you can establish security boundaries between clients using the same Valkey or Redis OSS cache or caches, and prevent clients from accessing each other's data.

RBAC is designed to support the introduction of [ACL](https://valkey.io/topics/acl/) [↗] (<https://valkey.io/topics/acl/>) in Redis OSS 6. When you use RBAC with your ElastiCache Valkey or Redis OSS cache, there are some limitations:

- A user group configured for the "VALKEY" engine can only contain users who are using an authentication mechanism (either password or IAM). This means all users with the engine "VALKEY", and any other users with the engine "Redis" who have their setup configured to authenticate with password or IAM, can be in this user group.
- When using RBAC with Valkey clusters, both user groups with engine "VALKEY" and with engine "REDIS" can be used.
- When using RBAC with Redis OSS clusters, only user groups with the engine "REDIS" can be used.
- You can't specify passwords in an access string. You set passwords with [CreateUser](https://docs.aws.amazon.com/AmazonElastiCache/latest/APIReference/API_CreateUser.html) (https://docs.aws.amazon.com/AmazonElastiCache/latest/APIReference/API_CreateUser.html) or [ModifyUser](https://docs.aws.amazon.com/AmazonElastiCache/latest/APIReference/API_ModifyUser.html) (https://docs.aws.amazon.com/AmazonElastiCache/latest/APIReference/API_ModifyUser.html) calls.
- For user rights, you enable or disable users with the `on` and `off` as a part of the access string. If neither is specified in the access string, the user is assigned `off` and doesn't have access rights to the cache.
- You can't use forbidden and renamed commands as part of the access string. If you specify a forbidden or a renamed command, an exception will be thrown. If you want to use access control lists (ACLs) for a renamed command, specify the original name of the command, in other words the name of the command before it was renamed.

- You can't use the `reset` command as a part of an access string. You specify passwords with API parameters, and ElastiCache for Valkey and Redis OSS manages passwords. Thus, you can't use `reset` because it would remove passwords for a user.
- Redis OSS 6 introduces the [ACL LIST](https://valkey.io/commands/acl-list) [↗] (<https://valkey.io/commands/acl-list>) command. This command returns a list of users along with the ACL rules applied to each user. ElastiCache supports the `ACL LIST` command, but does not include support for password hashes as Redis OSS does. With ElastiCache, you can use the [DescribeUsers](https://docs.aws.amazon.com/AmazonElastiCache/latest/APIReference/API_DescribeUsers.html) (https://docs.aws.amazon.com/AmazonElastiCache/latest/APIReference/API_DescribeUsers.html) operation to get similar information, including the rules contained within the access string. However, [DescribeUsers](https://docs.aws.amazon.com/AmazonElastiCache/latest/APIReference/API_DescribeUsers.html) (https://docs.aws.amazon.com/AmazonElastiCache/latest/APIReference/API_DescribeUsers.html) doesn't retrieve a user password.
- Other read-only commands supported by ElastiCache for Valkey and Redis OSS include [ACL WHOAMI](https://valkey.io/commands/acl-whoami) [↗] (<https://valkey.io/commands/acl-whoami>), [ACL USERS](https://valkey.io/commands/acl-users) [↗] (<https://valkey.io/commands/acl-users>), and [ACL CAT](https://valkey.io/commands/acl-cat) [↗] (<https://valkey.io/commands/acl-cat>). ElastiCache for Valkey and Redis OSS doesn't support any other write-based commands.
- The following limits apply:

Resource	Maximum allowed
Users per user group	100
Number of users	1000
Number of user groups	100

RBAC with Valkey

When using Role Based Access Control with Valkey, users and user groups are made with the "VALKEY" engine type. This is recommended, as by default Valkey with RBAC provides increased security compared to Redis OSS. Both provisioned and serverless Valkey clusters support VALKEY user and user group associations.

Key features of Valkey Access Control include:

- Valkey users are restricted to Valkey user group associations only.
- Valkey user groups can contain Valkey users, and Redis OSS users who are either password protected or IAM authentication is enabled.
- Valkey users must use either password protection or IAM authentication.
- VALKEY user groups can only be associated to VALKEY clusters
- There is no default user requirement. When the Valkey user group is attached to clusters, the default user requirement is automatically disabled. Customers will see that default user is turned off when using the `ACL LIST` command.

More information on using RBAC with ElastiCache for Valkey and Redis OSS follows.

Topics

- [Specifying Permissions Using an Access String \(#Access-string\)](#)
- [Applying RBAC to a Cache for ElastiCache for Valkey or Redis OSS \(#rbac-using\)](#)
- [Migrating from AUTH to RBAC \(#Migrate-From-RBAC-to-Auth\)](#)
- [Migrating from RBAC to AUTH \(#Migrate-From-RBAC-to-AUTH-1\)](#)
- [Automatically rotating passwords for users \(./User-Secrets-Manager.html\)](#)
- [Authenticating with IAM \(./auth-iam.html\)](#)

Specifying Permissions Using an Access String

To specify permissions to an ElastiCache Valkey or Redis OSS cache, you create an access string and assign it to a user through either the AWS CLI or AWS Management Console.

Access strings are defined as a list of space-delimited rules which are applied on the user. They define which commands a user can execute and which keys a user can operate on. In order to execute a command, a user must have access to the command being executed and all keys being accessed by the command. Rules are applied from left to right cumulatively, and a simpler string may be used instead of the one provided if there are redundancies in the string provided.

For information about the syntax of the ACL rules, see [ACL](https://valkey.io/topics/acl/) ^L (<https://valkey.io/topics/acl/>) .

In the following example, the access string represents an active user with access to all available keys and commands:

```
on ~* +@all
```

The access string syntax is broken down as follows:

- `on` – The user is an active user.
- `~*` – Access is given to all available keys.
- `+@all` – Access is given to all available commands.

The preceding settings are the least restrictive. You can modify these settings to make them more secure.

In the following example, the access string represents a user with access restricted to read access on keys that start "app::" keyspace

```
on ~app:* -@all +@read
```

You can refine these permissions further by listing commands the user has access to:

`+ command1` – The user's access to commands is limited to *command1* .

`+@category` – The user's access is limited to a category of commands.

For information on assigning an access string to a user, see [Creating Users and User Groups with the Console and CLI \(#Users-management\)](#) .

If you are migrating an existing workload to ElastiCache, you can retrieve the access string by calling `ACL LIST` , excluding the user and any password hashes.

For Redis OSS version 6.2 and above the following access string syntax is also supported:

- `&*` – Access is given to all available channels.

For Redis OSS version 7.0 and above the following access string syntax is also supported:

- `|` – Can be used for blocking subcommands (e.g "-config|set").
- `%R~<pattern>` – Add the specified read key pattern. This behaves similar to the regular key pattern but only grants permission to read from keys that match the given pattern. See [key permissions](https://valkey.io/topics/acl/) ^L (<https://valkey.io/topics/acl/>) for more information.
- `%W~<pattern>` – Add the specified write key pattern. This behaves similar to the regular key pattern but only grants permission to write to keys that match the given pattern. See [ACL key permissions](https://valkey.io/topics/acl/) ^L (<https://valkey.io/topics/acl/>) for more information.
- `%RW~<pattern>` – Alias for `~<pattern>` .

- (`<rule list>`) – Create a new selector to match rules against. Selectors are evaluated after the user permissions and are evaluated according to the order they are defined. If a command matches either the user permissions or selector, it is allowed. See [ACL selectors](https://valkey.io/topics/acl/) [↗] (<https://valkey.io/topics/acl/>) more information.
- `clearselectors` – Delete all of the selectors attached to the user.

Applying RBAC to a Cache for ElastiCache for Valkey or Redis OSS

To use ElastiCache for Valkey or Redis OSS RBAC, you take the following steps:

1. Create one or more users.
2. Create a user group and add users to the group.
3. Assign the user group to a cache that has in-transit encryption enabled.

These steps are described in detail as follows.

Topics

- [Creating Users and User Groups with the Console and CLI \(#Users-management\)](#)
- [Managing User Groups with the Console and CLI \(#User-Groups\)](#)
- [Assigning User Groups to Serverless Caches \(#Users-groups-to-serverless-caches\)](#)
- [Assigning User Groups to Replication Groups \(#Users-groups-to-RGs\)](#)

Creating Users and User Groups with the Console and CLI

The user information for RBAC users is a user ID, user name, and optionally a password and an access string. The access string provides the permission level on keys and commands. The user ID is unique to the user, and the user name is passed to the engine.

Make sure that the user permissions you provide make sense with the intended purpose of the user group. For example, if you create a user group called `Administrators`, any user you add to that group should have its access string set to full access to keys and commands. For users in an `e-commerce` user group, you might set their access strings to read-only access.

ElastiCache automatically configures a default user with user ID and user name `default` and adds it to all user groups. You can't modify or delete this user. This user is intended for compatibility with the default behavior of pre-Redis OSS versions and has an access string that permits it to call all commands and access all keys.

To add proper access control to a cache, replace this default user with a new one that isn't enabled or uses a strong password. To change the default user, create a new user with the user name set to `default`. You can then swap it with the original default user.

The following procedures show how to swap the original `default` user with another `default` user that has a more restrictive access string.

To modify the default user on the console

1. Sign in to the AWS Management Console and open the Amazon ElastiCache console at <https://console.aws.amazon.com/elasticache/> [↗] (<https://console.aws.amazon.com/elasticache/>).
2. Choose **User group management** from the navigation pane.
3. For **User group ID**, choose the ID that you want to modify. Make sure that you choose the link and not the checkbox.
4. Choose **Modify**.
5. In the **Modify** window, choose **Manage**. For "select the user that you want", select the user with the **User name** `default`.

6. Choose **Choose**.
7. Choose **Modify**. When you do this, any existing connections to a cache that the original default user has are terminated.

To modify the default user with the AWS CLI

1. Create a new user with the user name `default` by using the following commands.

For Linux, macOS, or Unix:

```
aws elasticache create-user \  
  --user-id "new-default-user" \  
  --user-name "default" \  
  --engine "VALKEY" \  
  --passwords "a-strong-password" \  
  --access-string "off +get ~keys"
```

For Windows:

```
aws elasticache create-user ^  
  --user-id "new-default-user" ^  
  --user-name "default" ^  
  --engine "VALKEY" ^  
  --passwords "a-strong-password" ^  
  --access-string "off +get ~keys"
```

2. Create a user group and add the user that you created previously.

For Linux, macOS, or Unix:

```
aws elasticache create-user-group \  
  --user-group-id "new-group-2" \  
  --engine "VALKEY" \  
  --user-ids "new-default-user"
```

For Windows:

```
aws elasticache create-user-group ^  
  --user-group-id "new-group-2" ^  
  --engine "VALKEY" ^  
  --user-ids "new-default-user"
```

When creating a user, you can set up to two passwords. When you modify a password, any existing connections to caches are maintained.

In particular, be aware of these user password constraints when using RBAC for ElastiCache for Valkey and Redis OS

- Passwords must be 16–128 printable characters.
- The following nonalphanumeric characters are not allowed: `, ' " / @`.

Managing Users with the Console and CLI

Use the following procedure to manage users on the console.

To manage users on the console

1. Sign in to the AWS Management Console and open the Amazon ElastiCache console at <https://console.aws.amazon.com/elasticache/> (<https://console.aws.amazon.com/elasticache/>).
2. On the Amazon ElastiCache dashboard, choose **User management**. The following options are available:
 - **Create user** – When creating a user, you enter a user ID, user name, authentication mode, and access string. The access string sets the permission level for what keys and commands the user is allowed. When creating a user, you can set up to two passwords. When you modify a password, any existing connections to caches are maintained.
 - **Modify user** – Enables you to update a user's authentication settings or change its access string.
 - **Delete user** – The account will be removed from any User Groups to which it belongs.

Use the following procedures to manage users with the AWS CLI.

To modify a user by using the CLI

- Use the `modify-user` command to update a user's password or passwords or change a user's access permissions. When a user is modified, the user groups associated with the user are updated, along with any caches associated with the user group. All existing connections are maintained. The following are examples.

For Linux, macOS, or Unix:

```
aws elasticache modify-user \  
  --user-id user-id-1 \  
  --access-string "~objects:* ~items:* ~public:~" \  
  --authentication-mode Type=iam
```

For Windows:

```
aws elasticache modify-user ^  
  --user-id user-id-1 ^  
  --access-string "~objects:* ~items:* ~public:~" ^  
  --authentication-mode Type=iam
```

Note

We don't recommend using the `nopass` option. If you do, we recommend setting the user's permissions to read-only with access to a limited set of keys.

To delete a user by using the CLI

- Use the `delete-user` command to delete a user. The account is deleted and removed from any user groups to which it belongs. The following is an example.

For Linux, macOS, or Unix:

```
aws elasticache delete-user \  
  --user-id user-id-2
```

For Windows:

```
aws elasticache delete-user ^  
  --user-id user-id-2
```


To see a list of users, call the [describe-users](https://docs.aws.amazon.com/cli/latest/reference/elasticache/describe-users.html) (https://docs.aws.amazon.com/cli/latest/reference/elasticache/describe-users.html) operation.

```
aws elasticache describe-users
```

Managing User Groups with the Console and CLI

You can create user groups to organize and control access of users to one or more caches, as shown following.

Use the following procedure to manage user groups using the console.

To manage user groups using the console

1. Sign in to the AWS Management Console and open the Amazon ElastiCache console at <https://console.aws.amazon.com/elasticache/> (https://console.aws.amazon.com/elasticache/).
2. On the Amazon ElastiCache dashboard, choose **User group management**.

The following operations are available to create new user groups:

- **Create** – When you create a user group, you add users and then assign the user groups to caches. For example, you can create an **Admin** user group for users who have administrative roles on a cache.

Important

If you are not using a Valkey or Redis OSS user group then you must include a default user when creating a user group.

- **Add Users** – Add users to the user group.
- **Remove Users** – Remove users from the user group. When users are removed from a user group, any existing connections they have to a cache are terminated.
- **Delete** – Use this to delete a user group. Note that the user group itself, not the users belonging to the group, will be deleted.

For existing user groups, you can do the following:

- **Add Users** – Add existing users to the user group.
- **Delete Users** – Removes existing users from the user group.

Note

Users are removed from the user group, but not deleted from the system.

Use the following procedures to manage user groups using the CLI.

To create a new user group and add a user by using the CLI

- Use the `create-user-group` command as shown following.

For Linux, macOS, or Unix:

```
aws elasticache create-user-group \
  --user-group-id "new-group-1" \
  --engine "VALKEY" \
  --user-ids user-id-1, user-id-2
```

For Windows:

```
aws elasticache create-user-group ^  
  --user-group-id "new-group-1" ^  
  --engine "VALKEY" ^  
  --user-ids user-id-1, user-id-2
```

To modify a user group by adding new users or removing current members by using the CLI

- Use the `modify-user-group` command as shown following.

For Linux, macOS, or Unix:

```
aws elasticache modify-user-group --user-group-id new-group-1 \  
  --user-ids-to-add user-id-3 \  
  --user-ids-to-remove user-id-2
```

For Windows:

```
aws elasticache modify-user-group --user-group-id new-group-1 ^  
  --user-ids-to-add user-id-3 ^  
  --user-ids-to-remove user-id-2
```

Note

Any open connections belonging to a user removed from a user group are ended by this command.

To delete a user group by using the CLI

- Use the `delete-user-group` command as shown following. The user group itself, not the users belonging to the group, is deleted.

For Linux, macOS, or Unix:

```
aws elasticache delete-user-group /  
  --user-group-id
```

For Windows:

```
aws elasticache delete-user-group ^  
  --user-group-id
```

To see a list of user groups, you can call the [describe-user-groups](https://docs.aws.amazon.com/cli/latest/reference/elasticache/describe-user-groups.html) (<https://docs.aws.amazon.com/cli/latest/reference/elasticache/describe-user-groups.html>) operation.

```
aws elasticache describe-user-groups \  
  --user-group-id test-group
```

Assigning User Groups to Serverless Caches

After you have created a user group and added users, the final step in implementing RBAC is assigning the user group to a serverless cache.

Assigning User Groups to Serverless Caches Using the Console

To add a user group to a serverless cache using the AWS Management Console, do the following:

- For cluster mode disabled, see [Creating a Valkey \(cluster mode disabled\) cluster \(Console\) \(./SubnetGroups.designer-cluster-pre.valkey.html#Clusters.Create.CON.valkey-gs\)](#)
- For cluster mode enabled, see [Creating a Valkey or Redis OSS \(cluster mode enabled\) cluster \(Console\) \(./Clusters.Create.html#Clusters.Create.CON.RedisCluster\)](#)

Assigning User Groups to Serverless Caches Using the AWS CLI

The following AWS CLI operation creates a serverless cache using the **user-group-id** parameter with the value *my-user-group-id* . Replace the subnet group *sng-test* with a subnet group that exists.

Key Parameters

- **--engine** – Must be VALKEY or REDIS .
- **--user-group-id** – This value provides the ID of the user group, comprised of users with specified access permissions for the cache.

For Linux, macOS, or Unix:

```
aws elasticache create-serverless-cache \  
  --serverless-cache-name "new-serverless-cache" \  
  --description "new-serverless-cache" \  
  --engine "VALKEY" \  
  --user-group-id "new-group-1"
```

For Windows:

```
aws elasticache create-serverless-cache ^  
  --serverless-cache-name "new-serverless-cache" ^  
  --description "new-serverless-cache" ^  
  --engine "VALKEY" ^  
  --user-group-id "new-group-1"
```

The following AWS CLI operation modifies a serverless cache with the **user-group-id** parameter with the value *my-user-group-id* .

For Linux, macOS, or Unix:

```
aws elasticache modify-serverless-cache \  
  --serverless-cache-name serverless-cache-1 \  
  --user-group-id "new-group-2"
```

For Windows:

```
aws elasticache modify-serverless-cache ^  
  --serverless-cache-name serverless-cache-1 ^  
  --user-group-id "new-group-2"
```

Note that any modifications made to a cache are updated asynchronously. You can monitor this progress by viewing events. For more information, see [Viewing ElastiCache events \(./ECEvents.Viewing.html\)](#) .

Assigning User Groups to Replication Groups

After you have created a user group and added users, the final step in implementing RBAC is assigning the user group to a replication group.

Assigning User Groups to Replication Groups Using the Console

To add a user group to a replication using the AWS Management Console, do the following:

- For cluster mode disabled, see [Creating a Valkey \(cluster mode disabled\) cluster \(Console\) \(./SubnetGroups.designer/cluster-pre.valkey.html#Clusters.Create.CON.valkey-gs\)](#)
- For cluster mode enabled, see [Creating a Valkey or Redis OSS \(cluster mode enabled\) cluster \(Console\) \(./Clusters.Create.html#Clusters.Create.CON.RedisCluster\)](#)

Assigning User Groups to Replication Groups Using the AWS CLI

The following AWS CLI operation creates a replication group with encryption in transit (TLS) enabled and the **user-group-ids** parameter with the value *my-user-group-id* . Replace the subnet group *sng-test* with a subnet group that exists.

Key Parameters

- **--engine** – Must be *valkey* or *redis* .
- **--engine-version** – Must be 6.0 or later.
- **--transit-encryption-enabled** – Required for authentication and for associating a user group.
- **--user-group-ids** – This value provides the ID of the user group, comprised of users with specified access permissions for the cache.
- **--cache-subnet-group** – Required for associating a user group.

For Linux, macOS, or Unix:

```
aws elasticache create-replication-group \  
  --replication-group-id "new-replication-group" \  
  --replication-group-description "new-replication-group" \  
  --engine "VALKEY" \  
  --cache-node-type cache.m5.large \  
  --transit-encryption-enabled \  
  --user-group-ids "new-group-1" \  
  --cache-subnet-group "cache-subnet-group"
```

For Windows:

```
aws elasticache create-replication-group ^  
  --replication-group-id "new-replication-group" ^  
  --replication-group-description "new-replication-group" ^  
  --engine "VALKEY" ^  
  --cache-node-type cache.m5.large ^  
  --transit-encryption-enabled ^  
  --user-group-ids "new-group-1" ^  
  --cache-subnet-group "cache-subnet-group"
```

The following AWS CLI operation modifies a replication group with encryption in transit (TLS) enabled and the **user-group-ids** parameter with the value *my-user-group-id* .

For Linux, macOS, or Unix:

```
aws elasticache modify-replication-group \  
  --replication-group-id replication-group-1 \  
  --user-group-ids-to-remove "new-group-1" \  
  --user-group-ids-to-add "new-group-2"
```

For Windows:

```
aws elasticache modify-replication-group ^  
  --replication-group-id replication-group-1 ^  
  --user-group-ids-to-remove "new-group-1" ^  
  --user-group-ids-to-add "new-group-2"
```

Note the `PendingChanges` in the response. Any modifications made to a cache are updated asynchronously. You can monitor this progress by viewing the events. For more information, see [Viewing ElastiCache events](#) ([./ECEvents.Viewing.html](#)).

Migrating from AUTH to RBAC

If you are using AUTH as described in [Authenticating with the Valkey and Redis OSS AUTH command](#) ([./auth.html](#)) and want to migrate to using RBAC, use the following procedures.

Use the following procedure to migrate from AUTH to RBAC using the console.

To migrate from Valkey or Redis OSS AUTH to RBAC using the console

1. Sign in to the AWS Management Console and open the ElastiCache console at <https://console.aws.amazon.com/elasticache/> (<https://console.aws.amazon.com/elasticache/>).
2. From the list in the upper-right corner, choose the AWS Region where the cache that you want to modify is located.
3. In the navigation pane, choose the engine that runs on the cache that you want to modify.
A list of the chosen engine's caches appears.
4. In the list of caches, for the cache that you want to modify, choose its name.
5. For **Actions**, choose **Modify**.
The **Modify** window appears.
6. For **Access control**, choose **User group access control list**.
7. For **User group access control list**, choose a user group.
8. Choose **Preview changes** and then on the next screen, **Modify**.

Use the following procedure to migrate from Valkey or Redis OSS AUTH to RBAC using the CLI.

To migrate from AUTH to RBAC using the CLI

- Use the `modify-replication-group` command as shown following.

For Linux, macOS, or Unix:

```
aws elasticache modify-replication-group --replication-group-id test \  
  --auth-token-update-strategy DELETE \  
  --user-group-ids-to-add user-group-1
```

For Windows:

```
aws elasticache modify-replication-group --replication-group-id test ^
--auth-token-update-strategy DELETE ^
--user-group-ids-to-add user-group-1
```

Migrating from RBAC to AUTH

If you are using RBAC and want to migrate to Redis OSS AUTH, see [Migrating from RBAC to AUTH \(./auth.html#Migrating-From-RBAC-to-AUTH\)](#) .

Note

If you need to disable access control on an ElastiCache cache, you'll need to do it through the AWS CLI. For more information, see [Disabling access control on an ElastiCache Valkey or Redis OSS cache \(./in-transit-encryption-disable.html\)](#) .

View related pages *Abstracts generated by AI*

Memorydb › devguide

Authenticating users with Access Control Lists (ACLs)...

ACLs authenticate MemoryDB users, controlling cluster access via permission-based access strings assigned user groups.

Get Started

[AWS Hands-On Tutorials](#)

[May 8, 2026](#)

Service Guides

Choosing a generative AI service

[AWS Solutions Library](#)

[AWS Decision Guides](#)

[AWS CLI Tutorials on GitHub](#)

Code-library › ug

MemoryDB examples using AWS CLI...

AWS CLI MemoryDB actions: manage clusters, snapshots, ACLs, subnet groups, parameter groups, shard failover.

Developer Tools

[AWS Code Example Library](#)

[May 8, 2026](#)

Helpful Links

Download the AWS CLI MCP Server

[Sign into the AWS Console](#)

[AWS re:Post](#)

;/?cmpid=docs_headercta_contactus)

_name=IAM&topic_url=https%3A%2F%2Fdocs.aws.amazon.com%2FIAM%2Flatest%2FUserGuide%2Fintroduction.html)



(<https://docs.aws.amazon.com>).



Get started
(#)

Service guides
(#)

Developer tools
(#)



[Documentation](https://docs.aws.amazon.com/index.html)

(<https://docs.aws.amazon.com/index.html>)



[AWS Identity and Access Management](https://docs.aws.amazon.com/iam/index.html)

(<https://docs.aws.amazon.com/iam/index.html>)



Use...

What is IAM?

[↓ PDF \(/pdfs/IAM/latest/UserGuide/iam-ug.pdf#introduction\)](#)

[↓ RSS \(aws-iam-release-notes.rss\)](#)

[↓ Markdown \(introduction.md\)](#)

☐ Focus mode

Related resources

[AWS Identity and Access Management API Reference](https://docs.aws.amazon.com/IAM/latest/APIReference) (<https://docs.aws.amazon.com/IAM/latest/APIReference>)

[AWS CLI commands for AWS Identity and Access Management](https://docs.aws.amazon.com/cli/latest/reference) (<https://docs.aws.amazon.com/cli/latest/reference>)

[SDKs & Tools](https://aws.amazon.com/tools/) [↗](https://aws.amazon.com/tools/) (<https://aws.amazon.com/tools/>)

▼ Recommended tasks

How to

[Troubleshoot sign-in issues for AWS account access](https://docs.aws.amazon.com/signin/latest/userguide/troubleshooting-sign-in-issues.html)

(<https://docs.aws.amazon.com/signin/latest/userguide/troubleshooting-sign-in-issues.html>)

[Install or update the latest version of the AWS CLI](https://docs.aws.amazon.com/cli/latest/userguide/getting-started-install.html)

(<https://docs.aws.amazon.com/cli/latest/userguide/getting-started-install.html>)

Learn about

[Understand when to use AWS Identity and Access Management](https://docs.aws.amazon.com/IAM/latest/UserGuide/when-to-use-iam.html)

(<https://docs.aws.amazon.com/IAM/latest/UserGuide/when-to-use-iam.html>)

[Understand the AWS account root user and best practices](https://docs.aws.amazon.com/IAM/latest/UserGuide/id_root-user.html)

(https://docs.aws.amazon.com/IAM/latest/UserGuide/id_root-user.html)

[Understand the features and capabilities of Amazon EC2](#)

(<https://docs.aws.amazon.com/AWSEC2/latest/UserGuide/concepts.html>)

Understand the benefits of using IAM to manage AWS access

(<https://docs.aws.amazon.com/IAM/latest/UserGuide/intro-iam-features.html>)

Understand AWS IAM Identity Center for workforce user access

(<https://docs.aws.amazon.com/singlesignon/latest/userguide/what-is.html>)

► Recently added to this guide

Did this page help you?

 Yes

 No

Provide feedback ([https://docs.aws.amazon.com/feedback/doc-feedback.html?](https://docs.aws.amazon.com/feedback/doc-feedback.html?hidden_service_name=IAM&topic_url=https%3A%2F%2Fdocs.aws.amazon.com%2FIAM%2Flatest%2FUserGuide)

[hidden_service_name=IAM&topic_url=https%3A%2F%2Fdocs.aws.amazon.com%2FIAM%2Flatest%2FUserGuide](https://docs.aws.amazon.com/feedback/doc-feedback.html?hidden_service_name=IAM&topic_url=https%3A%2F%2Fdocs.aws.amazon.com%2FIAM%2Flatest%2FUserGuide)

AWS Identity and Access Management (IAM) is a web service that helps you securely control access to AWS resources. With IAM, you can manage permissions that control which AWS resources users can use. IAM helps you control who is authenticated (signed in) and authorized (has permissions) to use AWS resources. IAM provides the infrastructure necessary to control authentication and authorization for your AWS resources.

Identities

When you create an AWS account, you begin with one sign-in identity called the AWS account root user. The root user has complete access to all AWS services and resources. We strongly recommend that you use the root user for everyday tasks. For tasks that require root user credentials, see [Tasks that require root user credentials](https://docs.aws.amazon.com/IAM/latest/UserGuide/id_root-user.html#root-user-tasks) (https://docs.aws.amazon.com/IAM/latest/UserGuide/id_root-user.html#root-user-tasks) in the *User Guide*.

Use IAM to set up other identities in addition to your root user, such as administrators, application developers, and grant them access to the resources they need to succeed in their tasks.

Access management

After a user is set up in IAM, they use their sign-in credentials to authenticate with AWS. Authentication is provided by matching the sign-in credentials to a principal (an IAM user, AWS STS federated user, or application) trusted by the AWS account. Next, a request is made to grant the principal access to the resources. Access is granted in response to an authorization request if the user has been granted access to the resource. For example, when you first sign in to the console and are on the console home page, you aren't accessing a specific service. When you select a service, the request for authorization is made and it looks to see if your identity is on the list of authorized users, what policies are attached to your identity, and if the policy allows access to the service.

to control the level of access granted, and any other policies that might be in effect. Auth can be made by principals within your AWS account or from another AWS account that yo

Once authorized, the principal can take action or perform operations on resources in your For example, the principal could launch a new Amazon Elastic Compute Cloud instance, m membership, or delete Amazon Simple Storage Service buckets.

Tip

AWS Training and Certification provides a 10-minute video introduction to IAM:

[Introduction to AWS Identity and Access Management](#) 

(<https://www.aws.training/learningobject/video?id=16448>) .

Service availability

IAM, like many other AWS services, is [eventually consistent](#)  (https://wikipedia.org/wiki/Eventual_consistency) . IAM achieves high availability by replicating data across multiple servers within Amazon's data centers around the world. If a request to change some data is successful, the change is committed and stored. However, the change must be replicated across IAM, which can take some time. Such changes include creating or updating users, groups, roles, or policies. We recommend that you do not rely on IAM changes in the critical, high-availability code paths of your application. Instead, make IAM changes in a separate initialization or setup routine that you run less frequently. Also, be sure to verify that IAM changes have been propagated before production workflows depend on them. For more information, see [IAM changes that I make are not always immediately visible](#) ([./troubleshoot.html#troubleshoot_general_eventual_consistency](#)) .

Service cost information

AWS Identity and Access Management (IAM), AWS IAM Identity Center and AWS Security Token Service (AWS STS) are features of your AWS account offered at no additional charge. You are charged when you access other AWS services using your IAM users or AWS STS temporary security credentials.

IAM Access Analyzer external access analysis is offered at no additional charge. However, IAM Access Analyzer charges for unused access analysis and customer policy checks. For a complete list of charges for IAM Access Analyzer, see [IAM Access Analyzer pricing](#)  (<https://aws.amazon.com/iam/access-analyzer/pricing/>) .

For information about the pricing of other AWS products, see the [Amazon Web Services pricing page](#) (<https://aws.amazon.com/pricing/>) .

Integration with other AWS services

IAM is integrated with many AWS services. For a list of AWS services that work with IAM and the features the services support, see [AWS services that work with IAM](#) ([./reference_aws-services-that-work-with-iam.html](#)) .

View related pages Abstracts generated by AI



Code-library › ug

[IAM examples using SDK for Rust...](#)

Rust SDK examples demonstrate creating users, assuming roles, managing policies, access keys, S3 bucket access.

May 7, 2026

Managedservices › ctref

[Identity and Access Management \(IAM\) | Creat...](#)

IAM access key creation via AMS console, inline RFC commands, or Change Management API using ct-2hhqzgxcvkcig8.

May 8, 2026

Cli › userguide

[AWS STS example AWS CLI...](#)

AWS CLI manage credentials via roles, decode a messages, verify

May 8, 2026

Discover highly rated pages Abstracts generated by AI



IAM › UserGuide

[Security best practices in IAM...](#)

Apply least-privilege permissions, use MFA, temporary credentials, and IAM Access Analyzer secure AWS resources.

May 8, 2026

IAM › UserGuide

[IAM Identities \(https://docs.aws.amazon.co...](#)

IAM identities—users, groups, roles—link policies defining authorized AWS actions, resources, conditions.

May 8, 2026

Rolesanywhere › i

[What is AWS Access Manag](#)

Obtain temporary credentials out X.509 certificate trust anchors.

May 8, 2026

Get Started

- AWS Hands-On Tutorials 
(https://aws.amazon.com/getting-started/hands-on/)
- AWS Solutions Library 
(https://aws.amazon.com/solutions/)
- AWS Decision Guides 
(https://aws.amazon.com/getting-started/decision-guides/)

Service Guides

- Choosing a generative AI service 
(https://docs.aws.amazon.com/ai-on-aws-how-to-choose/)
- AWS Service guides 
(https://docs.aws.amazon.com/service-ids/)
- AWS CLI Tutorials 
(https://github.com/aws-samples/sample-developer-tutorials)

Developer Tools

- AWS Code Example Library 
(https://docs.aws.amazon.com/code-library/latest/ug/what-is-code-library.html)
- AWS CLI 
(https://docs.aws.amazon.com/cli/)
- AWS Builder Center 
(https://builder.aws.com/)
- AWS Developer Tools Blog 
(https://aws.amazon.com/blogs/developer/)

Helpful Links

- Download the AWS Docs MCP Server 
(https://github.com/aws-labs/mcp/tree/main/doc-generation-mcp-server)
- Sign into the AWS Console 
(https://console.aws.amazon.com/)
- AWS re:Post 
(https://repost.aws/)

Top

[Privacy \(https://aws.amazon.com/privacy\)](https://aws.amazon.com/privacy) | [Site terms \(https://aws.amazon.com/terms\)](https://aws.amazon.com/terms) | [Cookie preferences \(#\)](#) | © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

English



Architecture strategies for identity and access management

Applies to this Azure Well-Architected Framework Security checklist recommendation:

 Expand table

SE:05 **Implement strict, conditional, and auditable identity and access management (IAM) across all workload users, team members, and system components. Limit access exclusively to *as necessary*. Use modern industry standards for all authentication and authorization implementations. Restrict and rigorously audit access that's not based on identity.**

This guide describes the recommendations for authenticating and authorizing identities that are attempting to access your workload resources.

From a technical control perspective, **identity is always the primary perimeter**. This scope doesn't just include the edges of your workload. It also includes individual components that are inside your workload. Typical identities include:

- **Humans.** Application users, admins, operators, auditors, and bad actors.
- **Systems.** Workload identities, managed identities, API keys, service principals, and Azure resources.
- **Anonymous.** Entities who haven't provided any evidence about who they are.

Terminology

 Expand table

Terms	Definition
Authentication (AuthN)	A process that verifies that an identity is who or what it says it is.
Authorization (AuthZ)	A process that verifies whether an identity has permission to perform a requested action.
Conditional access	A set of rules that allows actions based on specified criteria.
IdP	An identity provider, like Microsoft Entra ID.
Persona	A job function or a title that has a set of responsibilities and actions.

Terms	Definition
Preshared keys	A type of secret that's shared between a provider and consumer and used through a secure and agreed upon mechanism.
Resource identity	An identity defined for cloud resources that's managed by the platform.
Role	A set of permissions that define what a user or group can do.
Scope	Different levels of organizational hierarchy where a role is permitted to operate. Also a group of features in a system.
Security principal	An identity that provides permissions. It can be a user, a group, or a service principal. Any group members get the same level of access.
User identity	An identity for a person, like an employee or an external user.
Workload identity	A system identity for an application, service, script, container, or other component of a workload that's used to authenticate itself to other services and resources.

📌 Note

An identity can be grouped with other, similar identities under a parent called a *security principal*. A security group is an example of a security principal. This hierarchical relationship simplifies maintenance and improves consistency. Because identity attributes aren't handled at the individual level, chances of errors are also reduced. In this article, the term *identity* is inclusive of security principals.

The role of an identity provider

An identity provider (IdP) is a cloud-hosted service that stores and manages users as digital identities.

Take advantage of the capabilities provided by a trusted IdP for your identity and access management. Don't implement custom systems to replace an IdP. IdP systems are improved frequently based on the latest attack vectors by capturing billions of signals across multiple tenants each day. Microsoft Entra ID is the IdP for Azure cloud platform.

Authentication

Authentication is a process that verifies identities. The requesting identity is required to provide some form of verifiable identification. For example:

- A user name and password.

- A preshared secret, like an API key that grants access.
- A shared access signature (SAS) token.
- A certificate that's used in TLS mutual authentication.

As much as possible, the verification process should be handled by your IdP.

Authorization

Authorization is a process that allows or denies actions that are requested by the verified identity. The action might be operational or related to resource management.

Authorization requires that you assign permissions to the identities, which you need to do by using the functionality provided by your IdP.

To get a holistic view of the identity needs for a workload, you need to catalog the flows, workload assets, and personas, and the actions the assets and personas will perform. Your strategy must cover all use cases that handle **the flows that reach the workload or its components (outside-in access) and flows that reach out from the workload to other sources (inside-out access)**.

Each use case will probably have its own set of controls that you need to design with an assume-breach mindset. Based on the identity requirements of the use case or the personas, identify the conditional choices. Avoid using one solution for all use cases. Conversely, the controls shouldn't be so granular that you introduce unnecessary management overhead.

You need to log the identity access trail. Doing so helps validate the controls, and you can use the logs for compliance audits.

Determine all identities for authentication

- **Outside-in access.** Your identity design must authenticate all users that access the workload for various purposes. For example, an end user who accesses the application by calling APIs.

At a granular level, components of the workload might also need access from outside. For example, an operator who needs access through the portal or access to the compute to run commands.

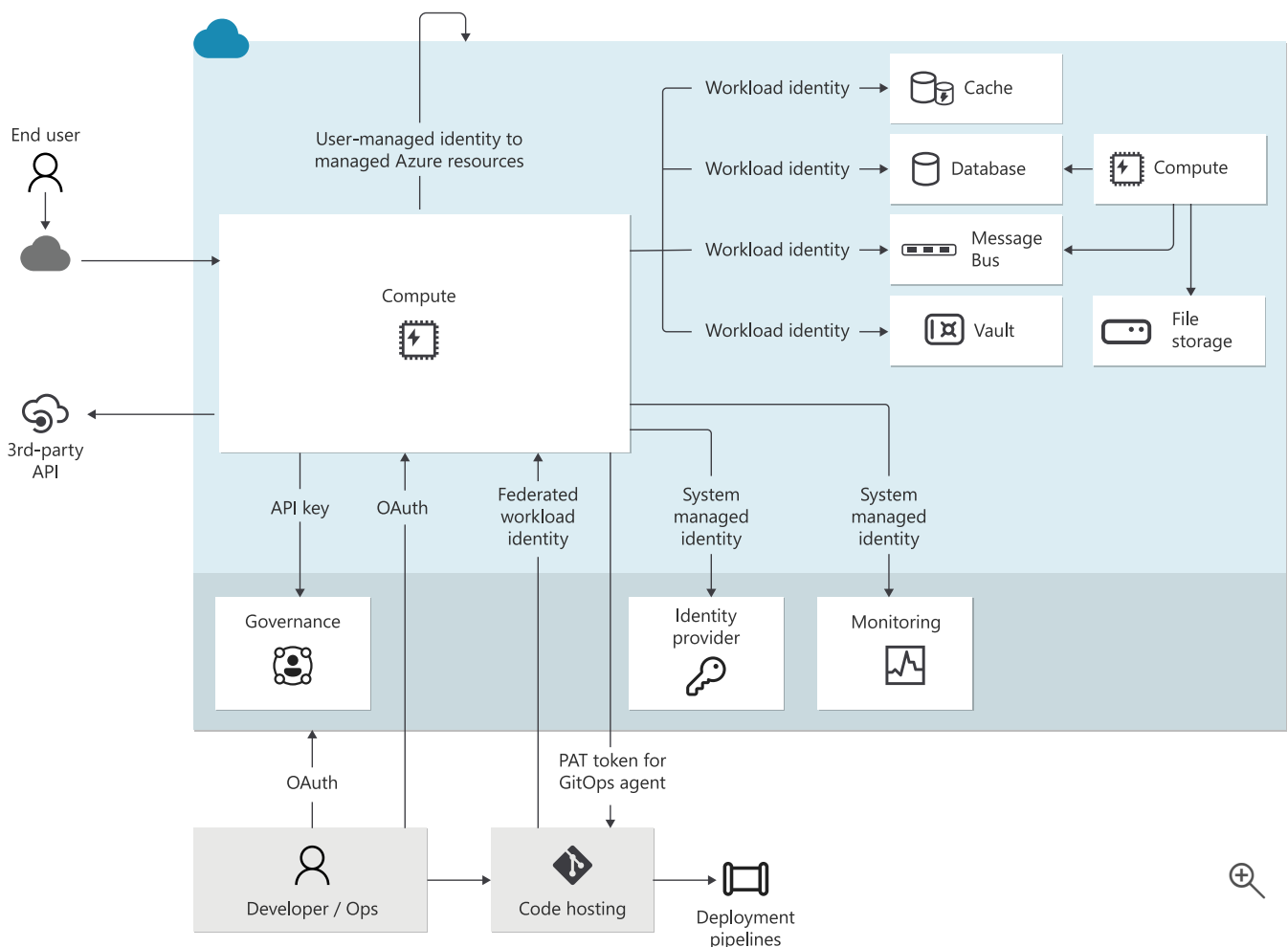
Both are examples of **user identities** that have different personas.

- **Inside-out access.** Your application will need to access other resources. For example, reading from or writing to the data platform, retrieving secrets from the secret store, and logging telemetry to monitoring services. It might even need to access third-party services. These access needs require **workload identity**, which enables the application to authenticate itself against the other resources.

The concept applies at the component level. In the following example, the container might need access to deployment pipelines to get its configuration. These access needs require **resource identity**.

All these identities should be authenticated by your IdP.

Here's an example of how identity can be implemented in an architecture:



Determine actions for authorization

Next, you need to know what each authenticated identity is trying to do so that those actions can be authorized. The actions can be divided by the type of access that they require:

- **Data plane access.** Actions that take place in the data plane cause data transfer for inside-out or outside-in access. For example, an application reading data from a database and writing data to a database, fetching secrets, or writing logs to a monitoring sink. At the component level, compute that's pulling or pushing images to or from a registry are considered data plane operations.
- **Control plane access.** Actions that take place in the control plane cause an Azure resource to be created, modified, or deleted. For example, changes to resource properties.

Applications typically target data plane operations, while operations often access both control and data planes. To identify authorization needs, note the operational actions that can be performed on the resource. For information about the permitted actions for each resource, see [Azure resource provider operations](#).

Provide role-based authorization

Based on the responsibility of each identity, authorize actions that should be permitted. **An identity must not be allowed to do more than it needs to do.** Before you set authorization rules, you need to have a clear understanding of who or what is making requests, what that role is allowed to do, and to what extent it can do it. Those factors lead to choices that combine identity, role, and scope.

Consider a workload identity as an example. The application must have data plane access to the database, so read and write actions to the data resource must be allowed. However, does the application need control plane access to the secret store? If the workload identity is compromised by a bad actor, what would the impact to the system be, in terms of confidentiality, integrity, and availability?

Role assignment

A role is a *set of permissions* that's assigned to an identity. Assign roles that only allow the identity to complete the task, and no more. When user's permissions are restricted to their job requirements, it's easier to identify suspicious or unauthorized behavior in the system.

Ask questions like these:

- Is read-only access enough?
- Does the identity need permissions to delete resources?

Limiting the level of access that users, applications, or services have to Azure resources reduces the potential attack surface. If you grant only the minimum permissions that are required to perform specific tasks, the risk of a successful attack or unauthorized access is significantly reduced. For example, security teams only need read-only access to security attributes for all technical environments. That level is enough to assess risk factors, identify potential mitigations, and report on the risks.

There are scenarios in which users need more access because of the organizational structure and team organization. There might be an overlap between various roles, or single users might perform multiple standard roles. In this case, use multiple role assignments that are based on the business function instead of creating a custom role for each of these users. Doing so makes the roles easier to manage.

Avoid permissions that specifically reference individual resources or users. Granular and custom permissions create complexity and confusion because they don't pass on the intention to new resources that are similar. This can create a complex legacy configuration that's difficult to maintain and negatively impact both security and reliability.



Tradeoff: A granular access control approach enables better auditing and monitoring of user activities.

A role also has an *associated scope*. The role can operate at the allowed management group, subscription, resource group, or resource scope, or at another custom scope. Even if the identity has a limited set of permissions, widening the scope to include resources that are outside the identity's job function is risky. For example, read access to all source code and data can be dangerous and must be controlled.

You assign roles to identities by using role-based access control (RBAC). **Always use IdP-provided RBAC** to take advantage of features that enable you to apply access control consistently and revoke it rigorously.

Use built-in roles. They're designed to cover most use cases. Custom roles are powerful and sometimes useful, but you should reserve them for scenarios in which built-in roles won't work. Customization leads to complexity that increases confusion and makes automation more complex, challenging, and fragile. These factors all negatively impact security.

Grant roles that start with least privilege and add more based your operational or data access needs. Your technical teams must have clear guidance to implement permissions.

If you want fine-grained control on RBAC, add conditions on the role assignment based on context, such as actions and attributes.

Make conditional access choices

Don't give all identities the same level of access. Base your decisions on two main factors:

- **Time.** How long the identity can access your environment.
- **Privilege.** The level of permissions.

Those factors aren't mutually exclusive. A compromised identity that has more privileges and unlimited duration of access can gain more control over the system and data or use that access to continue to change the environment. Constrain those access factors both as a preventive measure and to control the blast radius.

- *Just in Time (JIT)* approaches provide the required privileges only when they're needed.
- *Just Enough Access (JEA)* provides only the required privileges.

Although time and privilege are the primary factors, there are other conditions that apply. For example, you can also use the device, network, and location from which the access originated to set policies.

Use strong controls that filter, detect, and block unauthorized access, including parameters like user identity and location, device health, workload context, data classification, and anomalies.

For example, your workload might need to be accessed by third-party identities like vendors, partners, and customers. They need the appropriate level of access rather than the default permissions that you provide to full-time employees. Clear differentiation of external accounts makes it easier to prevent and detect attacks that come from these vectors.

Your choice of IdP must be able to provide that differentiation, provide built-in features that grant permissions based on the least privilege, and provide built-in threat intelligence. This includes monitoring of access requests and sign-ins. The Azure IdP is Microsoft Entra ID. For more information, see the [Azure facilitation section](#) of this article.

Protect critical impact accounts

Administrative identities introduce some of the highest impact security risks because the tasks they perform require privileged access to a broad set of these systems and applications.

Compromise or misuse can have a detrimental effect on your business and its information systems. Security of administration is one of the most critical security areas.

Protecting privileged access against determined adversaries requires you to take a complete and thoughtful approach to isolate these systems from risks. Here are some strategies:

- **Minimize the number of critical impact accounts.**
- **Use separate roles** instead of elevating privileges for existing identities.
- **Avoid permanent or standing access** by using the JIT features of your IdP. For break glass situations, follow an emergency access process.
- **Use modern access protocols** like passwordless authentication or multifactor authentication. Externalize those mechanisms to your IdP.
- Enforce key security attributes by using **conditional access policies**.
- **Decommission administrative accounts** that aren't being used.

Use a single identity across environments and associate a single identity with the user or principal. Consistency of identities across cloud and on-premises environments reduces human errors and the resulting security risks. Teams in both environments that manage resources need a consistent, authoritative source in order to meet security assurances. Work with your central identity team to ensure that identities in hybrid environments are synchronized.



Risk: There's a risk associated with synchronizing high privilege identities. An attacker can get full control of on-premises assets, and this can lead to a successful compromise of a cloud account. Evaluate your synchronization strategy by filtering out accounts that can add to the attack surface.

Establish processes to manage the identity lifecycle

Access to identities must not last longer than the resources that the identities access. Ensure that you have a process for disabling or deleting identities when there are changes in team structure or software components.

This guidance applies to source control, data, control planes, workload users, infrastructure, tooling, the monitoring of data, logs, metrics, and other entities.

Establish an identity governance process to manage the lifecycle of digital identities, high-privileged users, external/guest users, and workload users. Implement access reviews to ensure that when identities leave the organization or the team, their workload permissions are removed.

Protect nonidentity based secrets

Application secrets like preshared keys should be considered vulnerable points in the system. In the two-way communication, if the provider or consumer is compromised, significant security risks can be introduced. Those keys can also be burdensome because they introduce operational processes.

When you can, avoid using secrets and consider using identity-based authentication for user access to the application itself, not just to its resources.

The following list provides a summary of guidance. For more information, see [Recommendations for application secrets](#).

- Treat these secrets as entities that can be dynamically pulled from a secret store. They shouldn't be hard coded in your application code, IaC scripts, deployment pipelines, or in any other artifact.
- Be sure that you have the **ability to revoke secrets**.
- Apply operational practices that handle tasks like **key rotation and expiration**.

For information about rotation policies, see [Automate the rotation of a secret for resources that have two sets of authentication credentials](#) and [Tutorial: Updating certificate auto-rotation frequency in Key Vault](#).

Keep development environments safe

All code and scripts, pipeline tooling, and source control systems should be considered workload assets. **Access to writes should be gated** with automation and peer review. **Read access to source code should be limited** to roles on a need-to-know basis. Code repositories must have versioning, and **security code reviews** by peers must be a regular practice that's integrated with the development lifecycle. You need to have a process in place that **scans resources regularly** and identifies the latest vulnerabilities.

Use workload identities to grant access to resources from deployment environments, such as GitHub.

Maintain an audit trail

One aspect of identity management is ensuring that the system is auditable. Audits validate whether assume-breach strategies are effective. Maintaining an audit trail helps you:

- Verify that identity is authenticated with strong authentication. **Any action must be traceable** to prevent repudiation attacks.
- **Detect weak or missing authentication protocols** and get visibility into and insights about user and application sign-ins.
- Evaluate access from identities to the workload based on security and **compliance requirements** and consider user account risk, device status, and other criteria and policies that you set.
- **Track progress or deviation** from compliance requirements.

Most resources have data plane access. You need to know the identities that access resources and the actions that they perform. You can use that information for security diagnostics.

For more information, see [Recommendations on security monitoring and threat analysis](#).

Azure facilitation

We recommend that you always use modern authentication protocols that take into account all available data points and use conditional access. **Microsoft Entra ID provides identity and access management in Azure**. It covers the management plane of Azure and is integrated with the data planes of most Azure services. Microsoft Entra ID is the tenant that's associated with the workload subscription. It tracks and manages identities and their allowed permissions and simplifies overall management to minimize the risk of oversight or human error.

These capabilities natively integrate into the same Microsoft Entra identity and permission model for user segments:

- [Microsoft Entra ID](#). Employees and enterprise resources.
- [Microsoft Entra External ID](#). Partners.
- [Microsoft Entra federation compatibility list](#). Third-party federation solutions.

You can use Microsoft Entra ID for authentication and authorization of custom applications via Microsoft Authentication Library (MSAL) or platform features, like authentication for web apps. It

covers the management plane of Azure, the data planes of most of Azure services, and integration capabilities for your applications.

You can stay current by visiting [What's new in Microsoft Entra ID](#).



Tradeoff: Microsoft Entra ID is a single point of failure just like any other foundational service. There's no workaround until the outage is fixed by Microsoft. However, the rich feature set of Microsoft Entra outweighs the risk of using custom solutions.

Azure supports open protocols like OAuth2 and OpenID Connect. We recommend that you use these standard authentication and authorization mechanisms instead of designing your own flows.

Azure RBAC

Azure RBAC represents security principals in Microsoft Entra ID. All role assignments are done via Azure RBAC. Take advantage of built-in roles that provide most of the permissions that you need. For more information, see [Microsoft Entra built-in roles](#).

Here are some use cases:

- By assigning users to roles, you can control access to Azure resources. For more information, see [Overview of role-based access control in Microsoft Entra ID](#).
- You can use Privileged Identity Management to provide time-based and approval-based role activation for roles that are associated with high-impact identities. For more information, see [What is Privileged Identity Management?](#).

For more information about RBAC, see [Best practices for Azure RBAC](#).

For information about attribute-based controls, see [What is Azure ABAC?](#).

Workload identity

Microsoft Entra ID can handle your application's identity. The service principal that's associated with the application can dictate its access scope.

For more information, see [What are workload identities?](#).

The service principal is also abstracted when you use a managed identity. The advantage is that Azure manages all credentials for the application.

Not all services support managed identities. If you can't use managed identities, you can use service principals. However, using service principals increases your management overhead. For more information, see [What are managed identities for Azure resources?](#).

Resource identity

The concept of **managed identities can be extended to Azure resources**. Azure resources can use managed identities to authenticate themselves to other services that support Microsoft Entra authentication. For more information, see [Azure services that can use managed identities to access other services](#).

Conditional access policies

Conditional access describes your policy for an access decision. To use conditional access, you need to understand the restrictions that are required for the use case. Configure Microsoft Entra Conditional Access by setting up an access policy for that's based on your operational needs.

For more information, see [Conditional access: Users, groups, and workload identities](#).

Group access management

Instead of granting permissions to specific users, assign access to groups in Microsoft Entra ID. If a group doesn't exist, work with your identity team to create one. You can then add and remove group members outside of Azure and make sure that permissions are current. You can also use the group for other purposes, like mailing lists.

For more information, see [Secure access control using groups in Microsoft Entra ID](#).

Threat detection

Microsoft Entra ID Protection can help you detect, investigate, and remediate identity-based risks. For more information, see [What is Identity Protection?](#).

Threat detection can take the form of reacting to an alert of suspicious activity or proactively searching for anomalous events in activity logs. User and Entity Behavior Analytics (UEBA) in Microsoft Sentinel makes it easy to detect suspicious activities. For more information, see [Identify advanced threats with UEBA](#).

Hybrid systems

On Azure, **don't synchronize accounts to Microsoft Entra ID that have high privileges in your existing Active Directory**. This synchronization is blocked in the default Microsoft Entra Connect Sync configuration, so you only need to confirm that you haven't customized this configuration.

For information about filtering in Microsoft Entra ID, see [Microsoft Entra Connect Sync: Configure filtering](#).

Identity logging

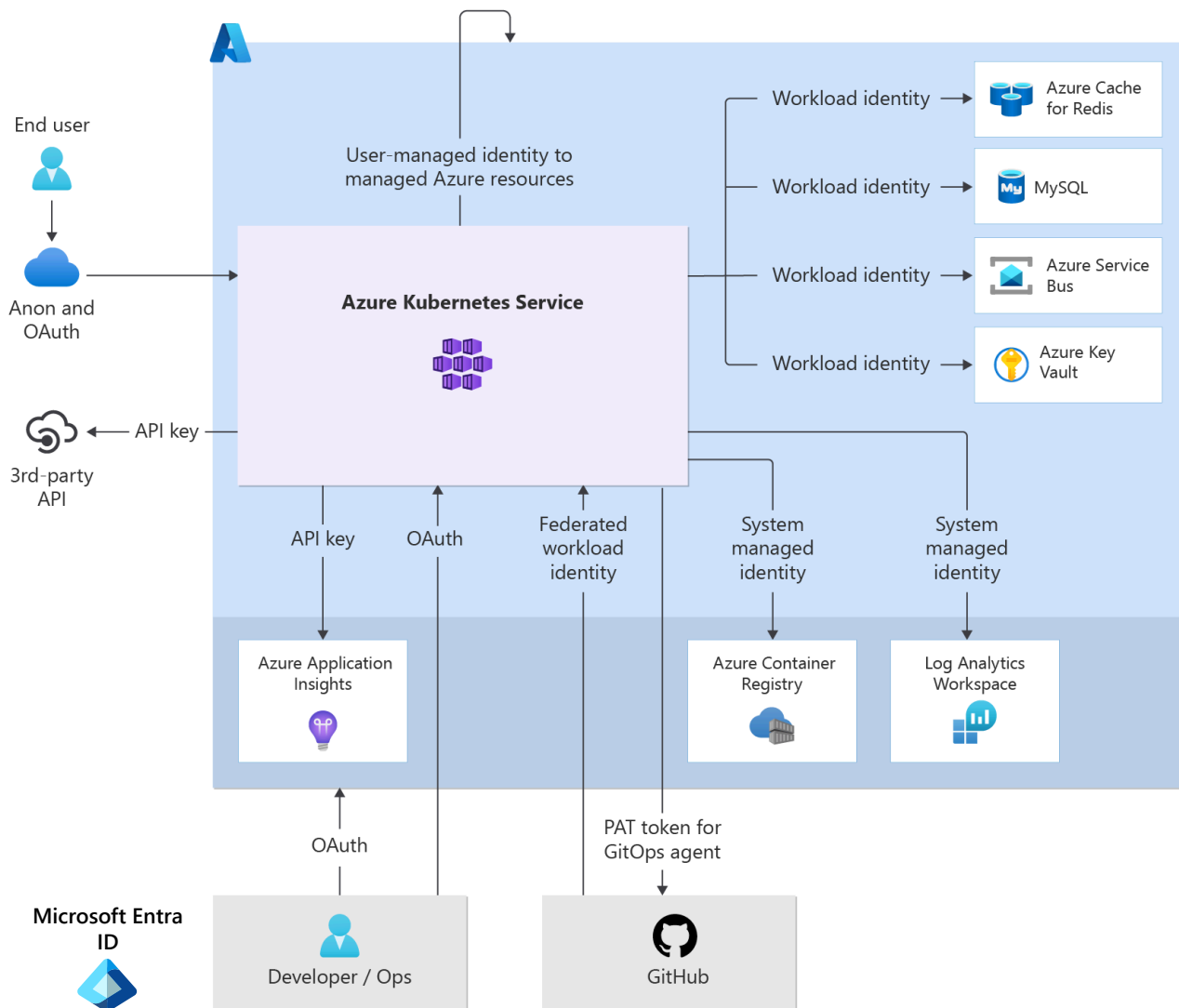
Enable diagnostic settings on Azure resources to emit information that you can use as an audit trail. The diagnostic information shows which identities attempt to access which resources and the outcome of those attempts. The collected logs are sent to Azure Monitor.



Tradeoff: Logging incurs costs because of the data storage that's used to store the logs. It also might cause a performance impact, especially on the code and on logging solutions that you add to the application.

Example

The following example shows an identity implementation. Different types of identities are used together to provide the required levels of access.



Identity components

- **System-managed identities.** Microsoft Entra ID provides access to service data planes that don't face users, like Azure Key Vault and data stores. These identities also control access, via RBAC, to the Azure management plane for workload components, deployment agents, and team members.
- **Workload identities.** The application services in the Azure Kubernetes Service (AKS) cluster use workload identities to authenticate themselves to other components in the solution.
- **Managed identities.** System components in the client role use system-managed identities, including build agents.

- **Human identities.** User and operator authentication is delegated to Microsoft Entra ID or Microsoft Entra ID (native, B2B, or B2C).

The security of preshared secrets is critical for any application. Azure Key Vault provides a secure storage mechanism for these secrets, including Redis and third-party secrets.

A rotation mechanism is used to help ensure that secrets aren't compromised. Tokens for the Microsoft identity platform implementation of OAuth 2 and OpenID Connect are used to authenticate users.

Azure Policy is used to ensure that identity components like Key Vault use RBAC instead of access policies. JIT and JEA provide traditional standing permissions for human operators.

Access logs are enabled across all components via Azure Diagnostics, or via code for code components.

Related links

- [Tutorial: Automate the rotation of a secret for resources that have two sets of authentication credentials](#)
- [Tutorial: Updating certificate auto-rotation frequency in Key Vault](#)
- [What's new in Microsoft Entra ID?](#)
- [Microsoft Entra built-in roles](#)
- [Overview of role-based access control in Microsoft Entra ID](#)
- [What are workload identities?](#)
- [What are managed identities for Azure resources?](#)
- [Conditional access: Users, groups, and workload identities](#)
- [Microsoft Entra Connect Sync: Configure filtering](#)

Security checklist

Refer to the complete set of recommendations.

Security checklist

Last updated on 11/15/2023

Shared responsibility in the cloud

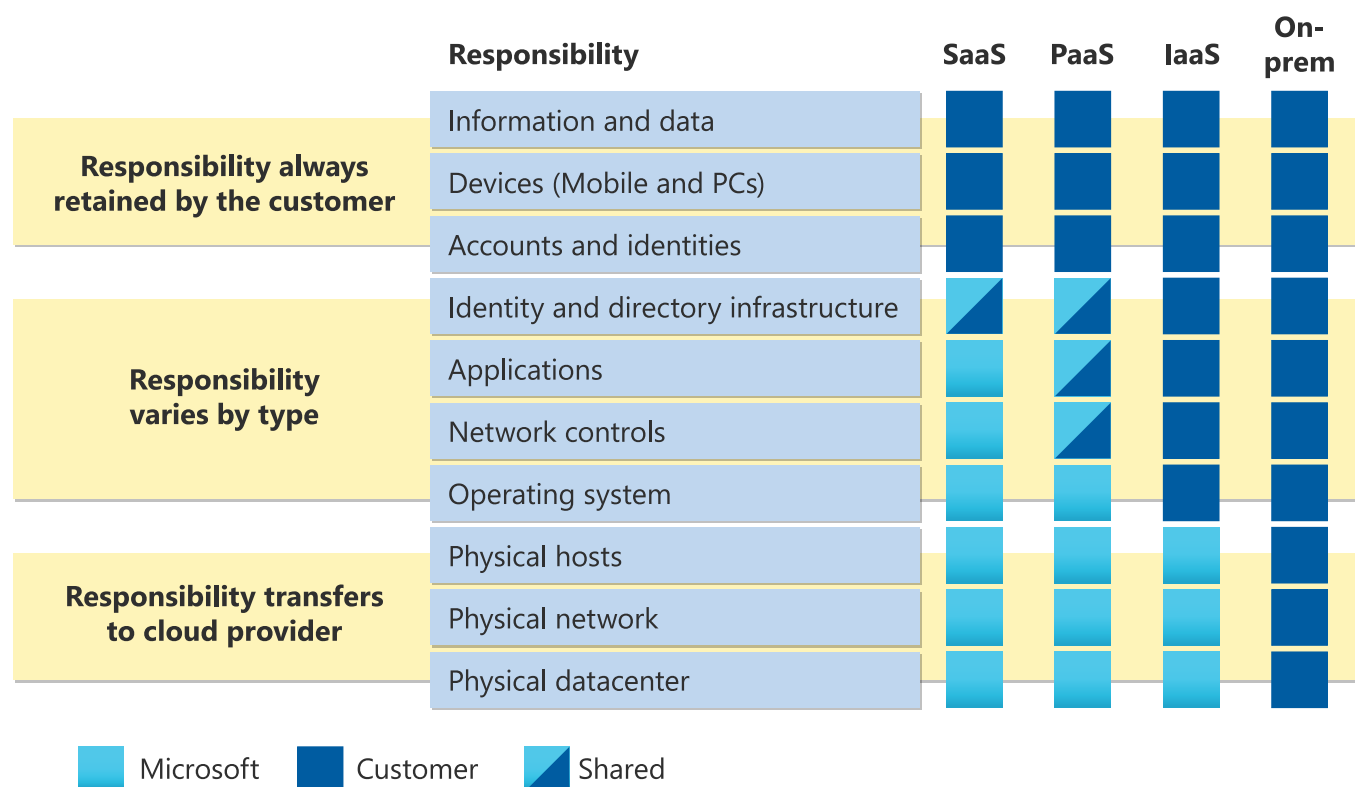
As you consider and evaluate public cloud services, it's critical to understand the shared responsibility model and which security tasks the cloud provider handles and which tasks you handle. The workload responsibilities vary depending on whether the workload is hosted on Software as a Service (SaaS), Platform as a Service (PaaS), Infrastructure as a Service (IaaS), or in an on-premises datacenter:

- **IaaS** (Infrastructure as a Service): You manage virtual machines, operating systems, and applications. Examples include Azure Virtual Machines, Azure Disk Storage, and virtual networks.
- **PaaS** (Platform as a Service): You deploy applications without managing VMs or operating systems. Examples include Azure App Service, Azure Functions, Azure SQL Database, and Azure Storage.
- **SaaS** (Software as a Service): You use ready-made applications. Examples include Microsoft 365, Dynamics 365, and other cloud applications.

Many Azure solutions use a combination of service models. For more detailed guidance on choosing compute services, see [Choose an Azure compute service](#).

Division of responsibility

In an on-premises datacenter, you own the whole stack. As you move to the cloud, some responsibilities transfer to Microsoft. The following diagram illustrates the areas of responsibility between you and Microsoft, according to the type of deployment of your stack.



For all cloud deployment types, you own your data and identities. You're responsible for protecting the security of your data and identities, on-premises resources, and the cloud components you control. Cloud components you control vary by service type.

Responsibility matrix

The following table details the division of responsibility between you and Microsoft for each area of your stack:

[Expand table](#)

Responsibility area	On-premises	IaaS	PaaS	SaaS
Customer data	Customer	Customer	Customer	Customer
Configurations and settings	Customer	Customer	Customer	Customer
Identities and users	Customer	Customer	Customer	Customer
Client devices	Customer	Customer	Customer	Shared
Applications	Customer	Customer	Shared	Shared
Network controls	Customer	Customer	Shared	Microsoft
Operating system	Customer	Customer	Microsoft	Microsoft
Physical hosts	Customer	Microsoft	Microsoft	Microsoft

Responsibility area	On-premises	IaaS	PaaS	SaaS
Physical network	Customer	Microsoft	Microsoft	Microsoft
Physical datacenter	Customer	Microsoft	Microsoft	Microsoft

Responsibilities you always retain

Regardless of the type of deployment, you always retain the following responsibilities:

- **Data** - You're responsible for your data, including data classification, data protection, encryption decisions, and compliance with data governance requirements.
- **Endpoints** - You're responsible for protecting client devices and endpoints that access your cloud services, including mobile devices, laptops, and desktops.
- **Accounts** - You're responsible for managing user accounts, including creating, managing, and removing user access.
- **Access management** - You're responsible for implementing and managing access controls, including role-based access control (RBAC), multifactor authentication, and conditional access policies.

Shared responsibilities explained

Some responsibilities are shared between you and Microsoft, with the division varying by service model:

- **Applications** - In IaaS, you're fully responsible for deployed applications. In PaaS and SaaS, Microsoft manages parts of the application stack, but you're responsible for application configuration, code security, and access controls.
- **Network controls** - In IaaS, you configure all network security including firewalls and network segmentation. In PaaS, Microsoft provides baseline network security, but you configure application-level network controls. In SaaS, Microsoft manages network security.
- **Client devices** - In SaaS scenarios, Microsoft may provide some device management capabilities, but you're responsible for endpoint protection and compliance.

Microsoft responsibilities

Microsoft is responsible for the underlying cloud infrastructure, which includes:

- **Physical security** - Securing datacenters, including facilities, physical access controls, and environmental controls.

- **Physical network** - Managing network infrastructure, including routers, switches, and cables within datacenters.
- **Physical hosts** - Managing and maintaining the physical servers that host cloud services.
- **Hypervisor** - Managing the virtualization layer that enables virtual machines in IaaS and PaaS.
- **Platform services** - In PaaS and SaaS, Microsoft manages operating systems, runtime environments, and middleware.

AI shared responsibility

When using AI services, the shared responsibility model introduces unique considerations beyond traditional IaaS, PaaS, and SaaS. Microsoft is responsible for securing the AI infrastructure, model hosting, and platform-level safeguards. Customers, however, remain accountable for how AI is applied within their environment—this includes protecting sensitive data, managing prompt security, mitigating prompt injection risks, and ensuring compliance with organizational and regulatory requirements.

Because responsibilities differ significantly for AI workloads, you should review the [AI Shared Responsibility Model](#) for detailed guidance on roles, best practices, and risk management.

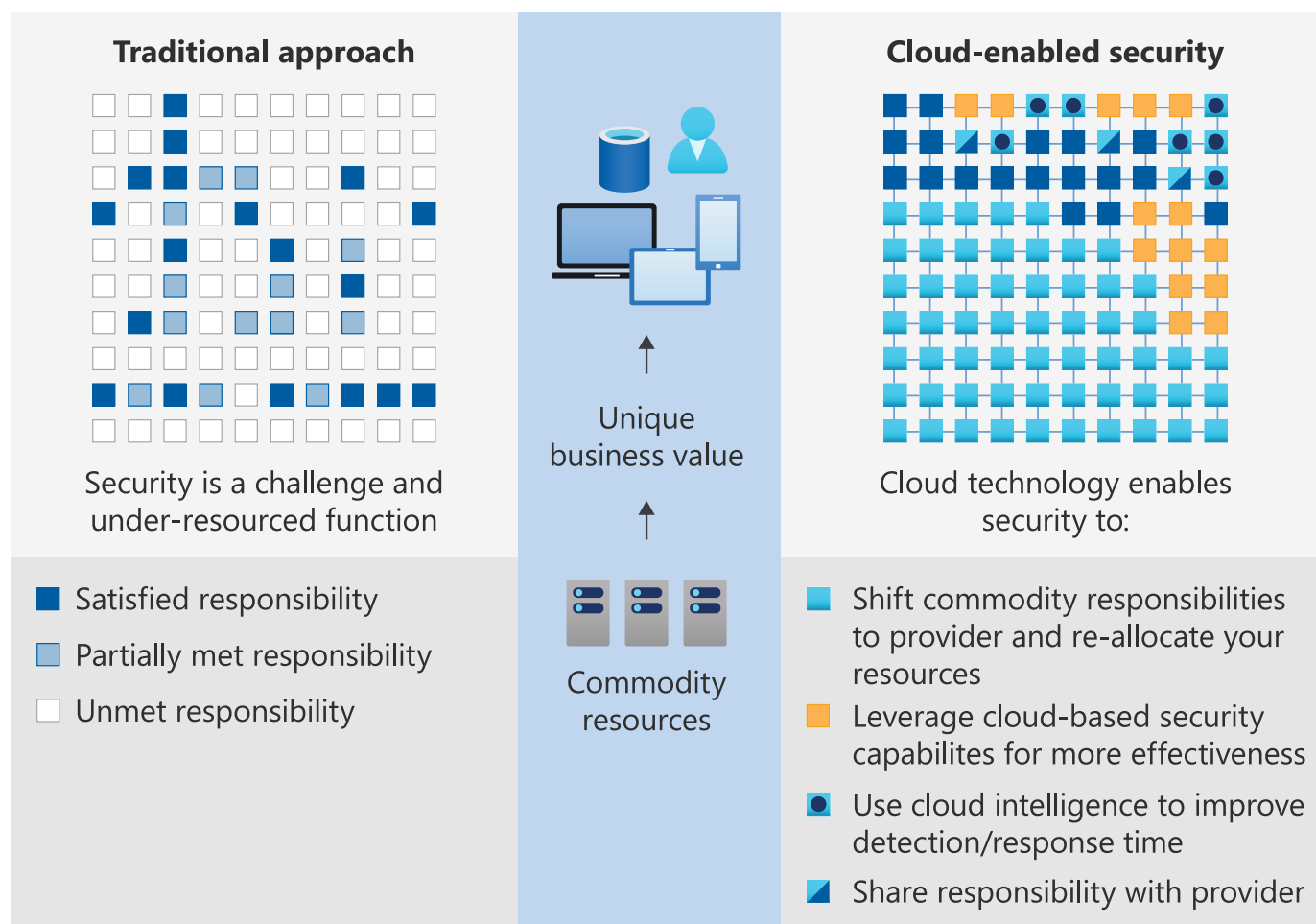
Cloud security advantages

The cloud offers significant advantages for solving long standing information security challenges. In an on-premises environment, organizations likely have unmet responsibilities and limited resources available to invest in security, which creates an environment where attackers are able to exploit vulnerabilities at all layers.

Common examples of unmet responsibilities in traditional on-premises environments include:

- **Delayed patching** - Security updates aren't applied promptly due to limited IT staff or concerns about system downtime, leaving known vulnerabilities exposed.
- **Inadequate physical security** - Server rooms may lack proper access controls, environmental monitoring, or surveillance due to budget constraints.
- **Incomplete network monitoring** - Organizations may not have tools or expertise to detect intrusions, monitor traffic anomalies, or respond to threats in real time.
- **Outdated hardware** - Aging infrastructure may no longer receive security updates from vendors, creating permanent security gaps.
- **Insufficient backup and disaster recovery** - Backups may be infrequent, untested, or stored on-site, leaving data vulnerable to ransomware or physical disasters.

The following diagram shows a traditional approach where many security responsibilities are unmet due to limited resources. In the cloud-enabled approach, you're able to shift day to day security responsibilities to your cloud provider and reallocate your resources.



In the cloud-enabled approach, you're also able to apply cloud-based security capabilities for more effectiveness and use cloud intelligence to improve your threat detection and response time. By shifting responsibilities to the cloud provider, organizations can get more security coverage, which enables them to reallocate security resources and budget to other business priorities.

Next step

Learn more about shared responsibility and strategies to improve your security posture in the Well-Architected Framework's [overview of the security pillar](#).

Last updated on 05/05/2026